

LỜI CẢM ƠN !

Sau thời gian 3 năm học tập và rèn luyện tại Khoa Khoa Học Máy Tính – trường CD CNTT Hữu Nghị Việt - Hàn, đến nay em đã hoàn thành đồ án tốt nghiệp và kết thúc khóa học. Em xin gửi lời cảm ơn chân thành đến lãnh đạo khoa, toàn thể các thầy cô giáo đã tận tình giảng dạy trang bị cho chúng em những kiến thức quý báu làm hành trang cho chúng em sau này.

Đặc biệt em xin gửi lời cảm ơn chân thành đến thầy giáo Nguyễn Vũ – Khoa Khoa Học Máy Tính đã trực tiếp hướng dẫn, giúp đỡ em có thể hoàn thành đồ án này. Cảm ơn sự đóng góp ý kiến của các thầy cô, bạn bè để em có thể hoàn thành đồ án này.

Đà Nẵng, tháng 06 năm 2013

Sinh viên

Cao Đức Duy

LỜI NÓI ĐẦU

Cùng với sự phát triển mạnh mẽ của ngành công nghệ thông tin, việc quản lý các tài nguyên thông tin, bao gồm nguồn thông tin (các thông tin về một doanh nghiệp, một tổ chức hay của một quốc gia nào đó) và việc bảo vệ chống lại sự truy cập bất hợp pháp ngày càng trở nên quan trọng. Từ đây nảy sinh ra một yêu cầu đó là cần có một giải pháp hoặc một hệ thống an ninh bảo vệ cho hệ thống mạng và luồng thông tin chạy trên nó.

Hệ thống phòng chống xâm nhập trái phép IPS là một phương pháp bảo mật có khả năng chống lại các kiểu tấn công mới, các vụ lạm dụng, dùng sai xuất phát từ trong hệ thống và có thể hoạt động tốt với các phương pháp bảo mật truyền thống. Nó đã được nghiên cứu, phát triển và ứng dụng từ lâu trên thế giới và đã thể hiện vai trò quan trọng trong các chính sách bảo mật. Snort là một ứng dụng mã nguồn mở miễn phí, nó có thể kết hợp với Iptable để tạo thành một hệ thống vững chắc dùng để phòng chống xâm nhập trái phép.

Từ những vấn đề nêu trên, em thực hiện đồ án này với mong muốn nghiên cứu những đặc trưng cơ bản của hệ thống phòng chống xâm nhập trái phép Snort-Inline cùng với Iptables với vai trò là phương pháp bảo mật mới bổ sung cho những phương pháp bảo mật hiện tại.

MỤC LỤC

LỜI NÓI ĐẦU.....	ii
DANH MỤC HÌNH ẢNH	vii
DANH MỤC BẢNG	viii
DANH MỤC CÁC TỪ VIẾT TẮT	ix
CHƯƠNG 1: TỔNG QUAN VỀ BẢO MẬT MẠNG.....	1
1.1 Một số mối đe dọa an ninh mạng và giải pháp phòng chống.....	1
1.1.1 Tấn công truy nhập mạng.....	1
1.1.1.1 Tấn công theo mật khẩu.....	1
1.1.1.2 Tấn công theo phân tích mật khẩu.	1
1.1.2 Tạo cửa hậu, xóa nhật ký.	2
1.1.3 Tấn công từ chối dịch vụ.	3
1.1.3.1 Tấn công SYN flood.	3
1.1.3.2 Tấn công UDP flood.....	3
1.1.4 Giả mạo địa chỉ IP.	4
1.1.5 Đùa nghịch, quấy rối.	4
1.1.6 Phá hoại.....	5
1.1.7 Gián điệp.....	5
1.1.8 Vô ý hay thiếu hiểu biết của người sử dụng.	5
1.2 Hệ thống phát hiện và ngăn chặn xâm nhập IDS/IPS.	5
1.2.1 Lịch sử ra đời.	5
1.2.2 Sự cần thiết của tìm kiếm và phát hiện xâm nhập.	6
1.2.3 Định nghĩa.....	6

1.2.4 Sự khác nhau giữa IDS và IPS.	8
1.2.5 Phân loại IDS/IPS và phân tích ưu nhược điểm.....	8
1.2.5.1 Network based IDS – NIDS	9
1.2.5.2 Host based IDS – HIDS.	11
1.2.6 Cơ chế hoạt động của hệ thống IDS/IPS.	13
1.2.6.1 Mô hình phát hiện sự lạm dụng.	13
1.2.6.2 Mô hình phát hiện sự bất thường.	14
1.2.6.3 So sánh giữa 2 mô hình.	17
2.1. Tổng quan về snort.	19
2.1.1. Giới thiệu về snort.	19
2.1.2. Kiến trúc của snort.	19
2.1.2.1. Module giải mã gói tin.	20
2.1.2.2. Module tiền xử lý.	20
2.1.2.3. Module phát hiện.	22
2.1.2.4. Module log và cảnh báo.	23
2.1.2.5. Module kết xuất thông tin.	23
2.1.3. Bộ luật của snort.	24
2.1.3.1. Giới thiệu.	24
2.1.3.2 Cấu trúc luật của snort.....	24
2.1.4. Cơ chế ngăn chặn của snort: snort – inline.....	31
2.1.4.1 Tích hợp khả năng ngăn chặn vào snort.	31
2.1.4.2 Những bổ sung cho cấu trúc luật của snort hỗ trợ inline mode.	31
2.2. Giới thiệu về Iptables.....	32
2.2.1 Cơ chế xử lý package trong IPtables.....	33

2.2.1.1 NAT table.	33
2.2.1.2 Filter table.....	33
2.2.1.3 Mangle table.	34
2.2.2 Một số khái niệm trong IPtables.	34
2.2.3 Các kiểu chặn trong IPtables.	35
2.2.3.1 Chặn theo giao thức.	35
2.2.3.2 Chặn gói ICMP (Ping).	36
2.2.3.3 Chặn dựa trên trạng thái kết nối.	37
2.2.4. Cài đặt Iptables.....	38
2.2.4.1. Các câu lệnh trợ giúp.	38
2.2.4.2. Các tùy chọn.	38
2.2.4.3. Các câu lệnh phục hồi.....	40
CHƯƠNG 3: TRIỂN KHAI SNORT VÀ IPTABLES.....	41
3.1. Mô hình hệ thống.	41
3.2. Triển khai mô hình hệ thống.	41
3.2.1 Cài đặt và cấu hình snort.	41
3.2.1.1 Cài đặt các gói phụ thuộc.....	41
3.2.1.2 Cài đặt snort.....	42
3.2.1.3 Cấu hình Snort.	43
3.2.1.4 Cài đặt và cấu hình base và adodb.	46
3.2.1.5 Cấu hình chế độ mod inline.	48
3.2.1.6 Khởi chạy snort-inline.....	49
3.2.2 Kiểm tra.	51
3.2.2.1 Tạo rule phát hiện	51

3.2.2.2 Tạo rule ngăn chặn.	53
KẾT LUẬN	viii
TÀI LIỆU THAM KHẢO.....	x

DANH MỤC HÌNH ẢNH

<i>Hình 1.1 Tấn công SYN Flood.....</i>	<i>3</i>
<i>Hình 1.2 Tấn công UDP flood.....</i>	<i>4</i>
<i>Hình 1.3 Các vị trí đặt IPS trong mạng.....</i>	<i>7</i>
<i>Hình 1.4 Mô hình NIDS.....</i>	<i>9</i>
<i>Hình 2.1. Mô hình kiến trúc hệ thống snort.</i>	<i>20</i>
<i>Hình 2.2. Cấu trúc luật của snort.....</i>	<i>24</i>
<i>Hình 2.3. Header luật của Snort.</i>	<i>25</i>
<i>Hình 2.4. Sơ đồ Netfilter/Iptables.....</i>	<i>32</i>
<i>Hình 2.5. Quá trình xử lý gói tin trong bảng NAT.</i>	<i>33</i>
<i>Hình 2.6. Quá trình xử lý gói tin trong bảng Filter.</i>	<i>34</i>
<i>Hình 2.7. Quá trình xử lý gói tin trong bảng Mangle</i>	<i>34</i>
<i>Hình 3.1. Mô hình hệ thống.....</i>	<i>41</i>

DANH MỤC BẢNG BIỂU

<i>Bảng 1.1. So sánh 2 mô hình phát hiện sự lạm dụng và bất thường.</i>	<i>17</i>
<i>Bảng 2.1. Các cờ sử dụng với từ khoá flags.</i>	<i>29</i>
<i>Bảng 2.2. Tùy chọn chặn theo giao thức trong IPtables.</i>	<i>35</i>
<i>Bảng 2.3. Tùy chọn chặn gói ICMP trong IPtables.</i>	<i>36</i>
<i>Bảng 2.4. Tùy chọn chặn dựa trên trạng thái kết nối trong IPtables.</i>	<i>37</i>
<i>Bảng 2.7. Câu lệnh hồi phục và các tùy chọn.</i>	<i>40</i>

DANH MỤC CÁC TỪ VIẾT TẮT

IPS	Intrusion Prevention System
IDS	Intrusion Detection System
HIDS	Host Intrusion Detection System
NIDS	Network Intrusion Detection System
DoS	Denial of Service
VPN	Virtual Private Network
IP	Internet Protocol
HP-UX	Hewlett-Packard UniX
AIX	Allied Intent Xtended
FDDI	Fiber Distributed Data Interface
HDLC	High-level Data Link Control
PPP	Purchasing power parity
TCP	Transmission Control Protocol
UDP	User Datagram Protocol
SNMP	Simple Network Management Protocol
SMB	Server Message Block
ICMP	Internet Control Message Protocol

BASE	Basic Analysis and Security Engine
HTTP	HyperText Transfer Protocol
FTP	File Transfer Protocol
SSH	Secure Shell
POP3	Post Office Protocol
MySQL	My Structured Query Language
AMD	Advanced Micro Devices

CHƯƠNG 1: TỔNG QUAN VỀ BẢO MẬT MẠNG.

1.2.1.1 Một số mối đe dọa an ninh mạng và giải pháp phòng chống.

1.1.1 Tấn công truy nhập mạng.

1.1.1.1 Tấn công theo mật khẩu.

Mật khẩu là tập hợp tất cả các chữ cái, chữ số.

Có hai cách tấn công theo mật khẩu:

- Tấn công thô: là dùng tất cả các tổ hợp, các kí tự để làm mật khẩu vào mạng và thử truy nhập, tấn công này thường dùng cho mạng LAN.

- Tấn công dùng từ điển: dự đoán một số từ khóa thông thường người ta hay dùng làm password, tấn công này thường dùng cho từ xa truy nhập vào mạng.

1.1.1.2 Tấn công theo phân tích mật khẩu.

Hầu hết trong các hệ điều hành đều lưu username và password. Nhưng mỗi hệ điều hành có các cách lưu khác nhau. Ví dụ, trong Window có file System_32/ config/ SAM/ Security Account, trong Linux, Unix có 2 file etc/passwd và etc/shadow. Trong các hệ điều hành thì hầu như password đều được mã hóa theo thuật toán DES và MD5 chứ nó không lưu bản rõ.

- Đối với Win 95,98 thì dùng thuật toán DES.

- Đối với Win NT và Win 2000 thì dùng thuật toán hàm băm MD4, sau đó sẽ sử dụng MD5.

- Đối với Win 2000 sau này dùng Kerberos.

Các thuật toán công khai như vậy thì người ta đều biết. Thông thường biết mã và thuật toán thì người ta giải mã được nhưng có một số thuật toán mà người ta giải mã rất khó như thuật toán DES thì người ta phải phá vài chục năm mới phá được (phương pháp này giống kiểu tấn công thô). Do đó, tin tặc sử dụng các kỹ thuật sau để tấn công:

- Sử dụng wordlist:

Danh sách của những từ sử dụng như danh mục địa phương, danh mục họ tên của nước nào đó. Đầu tiên dùng thuật toán mã hóa wordlist sau đó so sánh worslist đã mã hóa với mật khẩu. Có thể nói dùng phương pháp này cũng gần đi tới kết quả.

- Sử dụng chương trình giám điệp :

Tin tặc dùng chương trình này để copy các tệp mật khẩu. Khi copy được các tệp mật khẩu thì nó cũng có thể thay đổi mật khẩu được. Người dùng nên dùng password phức tạp để tin tặc tấn công khó hơn.

1.1.2 Tạo cửa hậu, xóa nhật ký.

Để tiếp tục tấn công vào lần sau (tấn công sau khi đã vào mạng).

- Hacker xóa các cổng truyền thông tạo ra các cổng truyền thông mới (nếu cổng truyền thông server không cho phép thì tạo ra để cho phép).

- Tạo ra người sử dụng mới, người sử dụng có quyền quản trị.

- Cài các chương trình cho phép tin tặc từ xa có thể điều khiển được, thường điều khiển để lấy thông tin hoặc phá hoại.

- Ngụy trang để xóa hết tên tệp, thay đổi tên thư mục, thay đổi những lệnh mà người quản trị sử dụng để phát hiện truy nhập.

- Xóa tệp nhật ký để cho người quản trị không thấy được dấu vết đã truy nhập hoặc có thể thay đổi tệp đăng ký, thay đổi thời gian ghi nhật ký. Ví dụ như khi truy nhập tuần này thì nó thay đổi thời gian là tuần trước (nhật ký tuần trước thì không thông báo) làm cho người quản trị không quản lý được.

Giải pháp phòng chống:

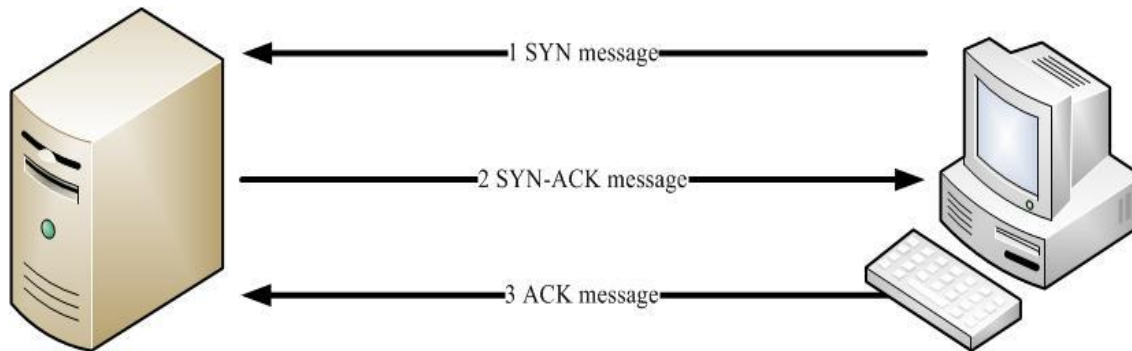
- Một số tệp quan trọng của hệ thống thì phải được bảo vệ tính toàn vẹn của nó thông qua việc tạo ra các tóm lược và sau một thời gian nhất định thì phải kiểm tra tệp đó có toàn vẹn không.

- Đối với một số nhật ký quan trọng thì được sao chép lưu giữ, bảo vệ để tin tặc không thay đổi được.

- Luôn kiểm tra các cổng truyền thông để phát hiện tin tặc có truyền thông tin ra từ máy không.

1.1.3 Tấn công từ chối dịch vụ.

1.1.3.1 Tấn công SYN flood.



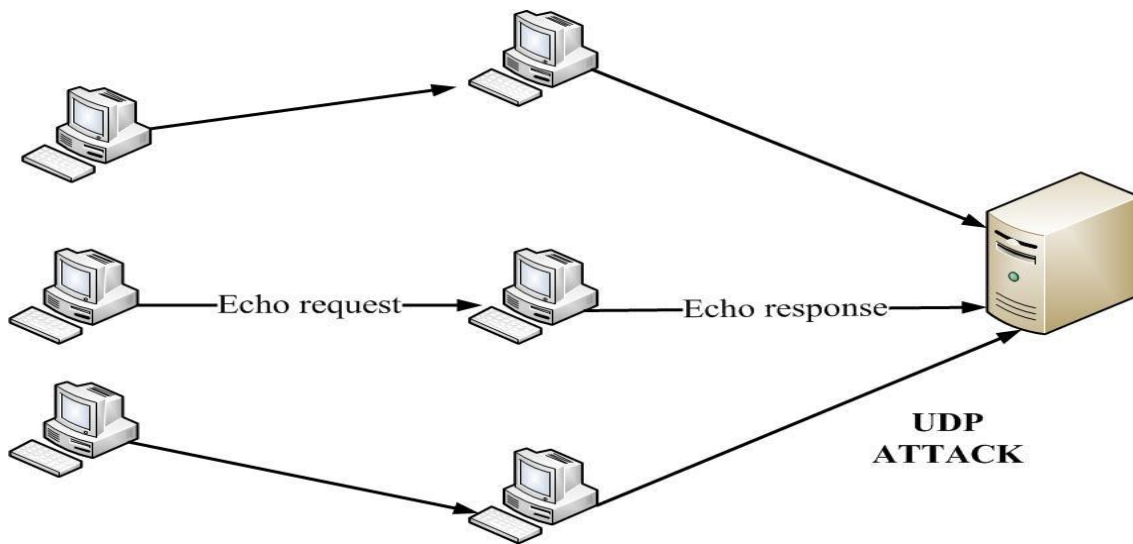
Hình 1.1 Tấn công SYN Flood.

Đầu tiên tin tặc gửi yêu cầu tới server, khi server nhận được yêu cầu của tin tặc thì server trả lời cho tin tặc nhưng tin tặc lại không xác nhận trả lời của server (ACK) làm cho server chờ trả lời. Khi server chờ hết thời gian Tout thì server buộc phải gửi yêu cầu hủy kết nối (RST/ACK). Khi tin tặc nhận được hủy kết nối thì tin tặc tiếp tục gửi tín hiệu SYN để yêu cầu kết nối và cứ như vậy server chỉ phục vụ cho tin tặc không phục được cái khác.

Giải pháp phòng chống:

- Có một số firewall chặn một số cổng SYN như Checkpoint.
- Làm tăng hàng đợi server có thể phục vụ.
- Xác định Tout một cách mềm dẻo có thể tránh được tắc nghẽn do tin tặc gây ra.
- Xác định thêm một bộ đệm để biết được chu trình thiết lập liên kết một nửa và từ đó có quy trình để đối phó.
- Kết hợp các công cụ của hệ điều hành.

1.1.3.2 Tấn công UDP flood



Hình 1.2 Tấn công UDP flood.

Tấn công UDP flood là tin tặc gửi rất nhiều UDP làm cho server không kịp xử lý.

Giải pháp phòng chống:

Sử dụng firewall, chỉ cho phép các dịch vụ UDP cần thiết buộc phải có như DNS, DHCP, SNMP. Những gói UDP của các dịch vụ này thì bắt buộc phải cho vào mạng còn các gói UDP của các dịch vụ khác thì không cần thiết.

1.1.4 Giả mạo địa chỉ IP.

Việc giả mạo địa chỉ IP có thể được thực hiện thông qua việc sử dụng khả năng dẫn đường trực tiếp. Với cách tấn công này, tin tặc gửi các gói IP tới mạng bên trong với địa chỉ IP giả mạo (thông thường là địa chỉ của một mạng hoặc một máy được coi là an toàn đối với mạng bên trong), đồng thời phải chỉ rõ đường dẫn mà các gói tin IP phải gửi đi.

1.1.5 Đùa nghịch, quấy rối.

Là do con người có tính tò mò, xâm nhập vào hệ thống tìm những thông tin mà họ thích thú. Họ thường làm hỏng hệ thống do thiếu kiến thức hoặc cố gắng che dấu vết của họ.

1.1.6 Phá hoại.

Là những người cố ý phá hoại hệ thống thông tin mà họ muốn. Những người này thường là họ bất bình trong môi trường làm việc của họ, hoặc do tính chất cạnh tranh nào đó. Chúng có thể xóa dữ liệu hoặc làm hỏng thiết bị hệ thống mà chúng xâm nhập.

1.1.7 Gián điệp.

Là những người xâm nhập vào hệ thống và chỉ lấy những thông tin nào có giá trị lớn như các hệ thống tín dụng, ngân hàng... Khó phát hiện tức thời được, thường chúng lấy thông tin mà không để lại dấu vết.

1.1.8 Vô ý hay thiếu hiểu biết của người sử dụng.

Các tai họa hoàn toàn không phải do kẻ xấu làm nên, mà đa số là do những người chưa được đào tạo tốt về kiến thức máy tính nên không nhận thức được các mối nguy hiểm cho hệ thống và do những người quản trị hệ thống thiếu kinh nghiệm, hoặc lỗi của một chương trình ứng dụng.

1.2. Hệ thống phát hiện và ngăn chặn xâm nhập IDS/IPS.

1.2.1 Lịch sử ra đời.

Cách đây khoảng 25 năm, khái niệm phát hiện xâm nhập xuất hiện qua một bài báo của James Anderson. Khi đó người ta cần IDS với mục đích là dò tìm và nghiên cứu các hành vi bất thường và thái độ của người sử dụng trong mạng, phát hiện ra các việc làm dụng đặc quyền để giám sát tài sản hệ thống mạng. Các nghiên cứu về hệ thống phát hiện xâm nhập được nghiên cứu chính thức từ năm 1983 đến năm 1988 trước khi được sử dụng tại mạng máy tính của không lực Hoa Kỳ. Cho đến tận năm 1996, các khái niệm IDS vẫn chưa được phổ biến, một số hệ thống IDS chỉ được xuất hiện trong các phòng thí nghiệm và viện nghiên cứu. Tuy nhiên trong thời gian này, một số công nghệ IDS bắt đầu phát triển dựa trên sự bùng nổ của công nghệ thông tin. Đến năm 1997 IDS mới được biết đến rộng rãi và thực sự đem lại lợi nhuận với sự đi đầu của công ty ISS, một năm sau đó, Cisco nhận ra tầm quan trọng của IDS và đã mua lại một công ty cung cấp giải pháp IDS tên là Wheel.

Hiện tại, các thống kê cho thấy IDS/IPS đang là một trong các công nghệ an ninh được sử dụng nhiều nhất và vẫn còn phát triển.

1.2.2 Sự cần thiết của tìm kiếm và phát hiện xâm nhập.

Ngày nay, an toàn mạng đã trở thành một vấn đề hết sức quan trọng. Những kẻ phá hoại và xâm nhập mạng đã đạt được nhiều thành công trong việc tấn công vào các thành phần và các dịch vụ mạng. Nhiều phương pháp đã được phát triển để đảm bảo an toàn cho hạ tầng và cho truyền thông trên mạng Internet, ta có thể kể tới một số phương pháp điển hình như: sử dụng bức tường lửa, mã hoá dữ liệu và các mạng riêng ảo. Phát hiện xâm nhập mạng là một kỹ thuật mới, được xuất hiện cách đây vài năm. Sử dụng phương pháp phát hiện xâm nhập, ta có thể thu thập và sử dụng các dấu vết từ những kiểu tấn công đã được biết trước, từ đó tìm ra xem liệu có kẻ nào đó đang cố gắng tấn công vào mạng hay máy của bạn. Những thông tin được thu thập theo cách này sẽ được sử dụng để làm tăng khả năng an toàn cho mạng cũng như cho các mục đích khác. Kỹ thuật phát hiện xâm nhập mạng hiện đã được cài đặt trong các sản phẩm thương mại cũng như trong sản phẩm có mã nguồn mở. Ngoài ra, còn phải kể tới nhiều công cụ phát hiện các lỗ hổng giúp phát hiện các lỗ hổng an toàn trong mạng.

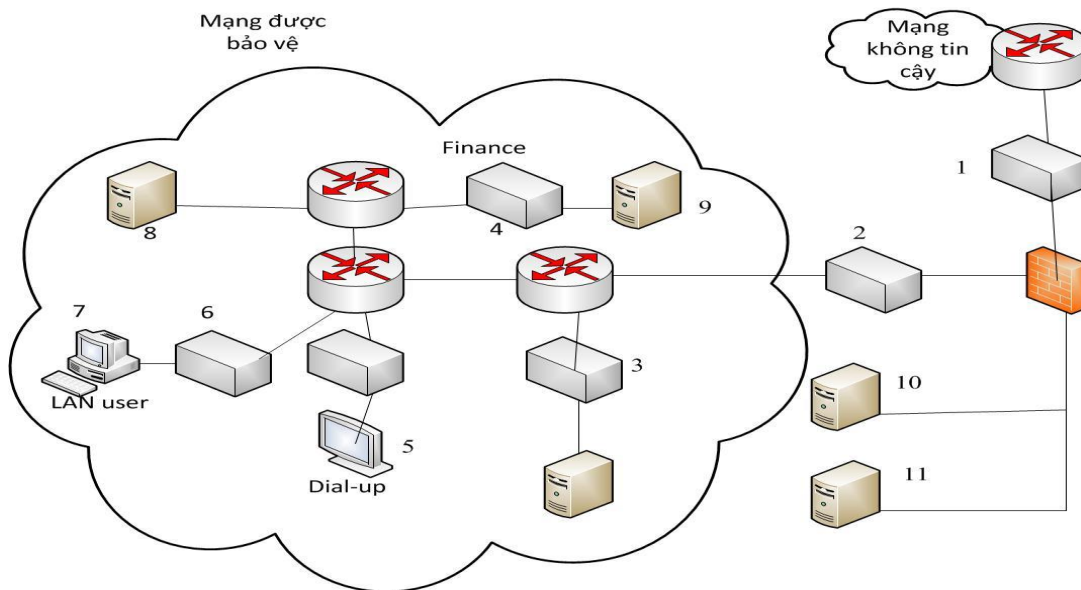
1.2.3 Định nghĩa.

Hệ thống phát hiện xâm nhập (IDS) là hệ thống có nhiệm vụ theo dõi, phát hiện và (có thể) ngăn cản sự xâm nhập, cũng như các hành vi khai thác trái phép tài nguyên của hệ thống được bảo vệ mà có thể dẫn đến việc làm tổn hại đến tính bảo mật, tính toàn vẹn và tính sẵn sàng của hệ thống.

Hệ thống IDS sẽ thu thập thông tin từ rất nhiều nguồn trong hệ thống được bảo vệ sau đó tiến hành phân tích những thông tin đó theo các cách khác nhau để phát hiện những xâm nhập trái phép.

Khi một hệ thống IDS có khả năng ngăn chặn các nguy cơ xâm nhập mà nó phát hiện được thì nó được gọi là một hệ thống phòng chống xâm nhập hay IPS.

Hình sau minh họa các vị trí thường cài đặt IPS trong mạng :



Hình 1.3 Các vị trí đặt IPS trong mạng.

Phân đoạn mạng Internet: Thiết bị IPS 1 bảo vệ toàn bộ hệ thống mạng bên trong trước các xâm nhập từ bên ngoài Internet. Thay vì kiểm tra các giao thông mạng từ ngoài tường lửa, thiết bị IPS 2 sẽ chỉ phải kiểm tra các giao thông mạng đã được tường lửa cho phép đi qua và bảo vệ hệ thống mạng bên trong.

Phân đoạn mạng Extranet: Thiết bị IPS 3 bảo vệ hệ thống mạng của cơ quan/tổ chức khi kết nối với hệ thống mạng của đối tác.

Phân đoạn mạng Intranet: thiết bị IPS bảo vệ từng đoạn mạng trong hệ thống. Ví dụ như IPS 4 bảo vệ vùng máy chủ Finance trước các tấn công từ các vùng mạng khác. Các thiết bị IPS 4, 6 này sẽ ngăn chặn các tấn công giữa các đoạn mạng trong một hệ thống mạng.

Phân đoạn mạng truy cập từ xa: thiết bị IPS 5 ngăn chặn các xâm nhập xuất phát từ các kết nối dial-up vào trong hệ thống mạng cần bảo vệ.

Trên máy chủ và máy trạm: các phần mềm IPS 7-11 được cài đặt lên máy chủ và máy trạm, bảo vệ các máy chủ và máy trạm này.

1.2.4 Sự khác nhau giữa IDS và IPS.

Có thể nhận thấy sự khác biệt giữa hai khái niệm ngay ở tên gọi: “phát hiện” và “ngăn chặn”. Các hệ thống IDS được thiết kế với mục đích chủ yếu là phát hiện và cảnh báo các nguy cơ xâm nhập đối với mạng máy tính nó đang bảo vệ trong khi đó, một hệ thống IPS ngoài khả năng phát hiện còn có thể tự hành động chống lại các nguy cơ theo các quy định được người quản trị thiết lập sẵn.

Tuy vậy, sự khác biệt này trên thực tế không thật sự rõ ràng. Một số hệ thống IDS được thiết kế với khả năng ngăn chặn như một chức năng tùy chọn. Trong khi đó một số hệ thống IPS lại không mang đầy đủ chức năng của một hệ thống phòng chống theo đúng nghĩa.[8]

Một câu hỏi được đặt ra là lựa chọn giải pháp nào, IDS hay IPS? Câu trả lời tùy thuộc vào quy mô, tính chất của từng mạng máy tính cụ thể cũng như chính sách an ninh của những người quản trị mạng. Trong trường hợp các mạng có quy mô nhỏ, với một máy chủ an ninh, thì giải pháp IPS thường được cân nhắc nhiều hơn do tính chất kết hợp giữa phát hiện, cảnh báo và ngăn chặn của nó. Tuy nhiên với các mạng lớn hơn thì chức năng ngăn chặn thường được giao phó cho một sản phẩm chuyên dụng như một firewall chẳng hạn. Khi đó, hệ thống cảnh báo sẽ chỉ cần theo dõi, phát hiện và gửi các cảnh báo đến một hệ thống ngăn chặn khác. Sự phân chia trách nhiệm này sẽ làm cho việc đảm bảo an ninh cho mạng trở nên linh động và hiệu quả hơn.[8]

1.2.5 Phân loại IDS/IPS và phân tích ưu nhược điểm.

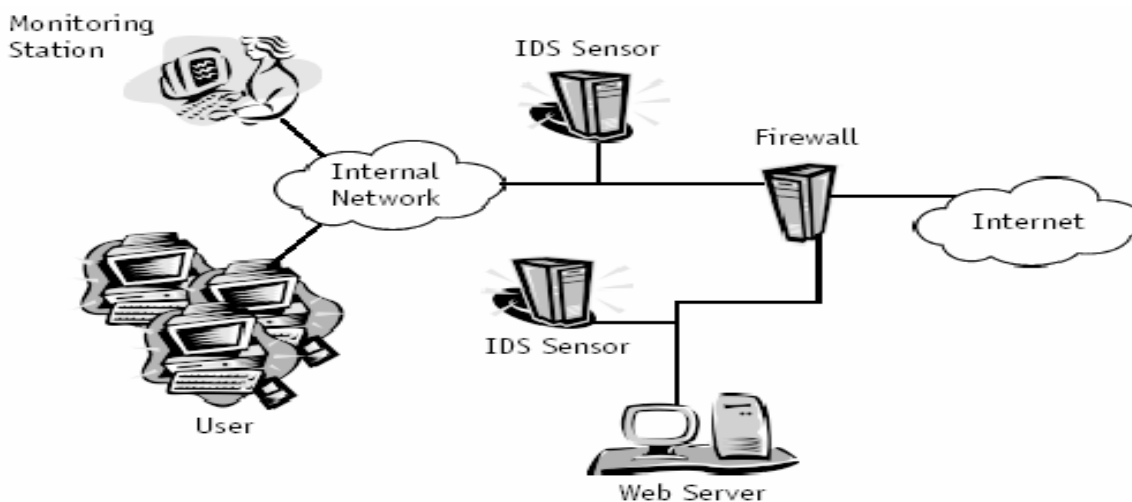
Cách thông thường nhất để phân loại các hệ thống IDS (cũng như IPS) là dựa vào đặc điểm của nguồn dữ liệu thu thập được. Trong trường hợp này, các hệ thống IDS được chia thành các loại sau:

- Host-based IDS (HIDS): Sử dụng dữ liệu kiểm tra từ một máy trạm đơn để phát hiện xâm nhập.
- Network-based IDS (NIDS): Sử dụng dữ liệu trên toàn bộ lưu thông mạng, cùng với dữ liệu kiểm tra từ một hoặc một vài máy trạm để phát hiện xâm nhập.

1.2.5.1 Network based IDS – NIDS

NIDS thường bao gồm có hai thành phần logic :

- Bộ cảm biến – Sensor : đặt tại một đoạn mạng, kiểm soát các cuộc lưu thông nghi ngờ trên đoạn mạng đó.
- Trạm quản lý : nhận các tín hiệu cảnh báo từ bộ cảm biến và thông báo cho một điều hành viên.



Hình 1.4 Mô hình NIDS.

Ưu điểm

- Chi phí thấp : Do chỉ cần cài đặt NIDS ở những vị trí trọng yếu là có thể giám sát lưu lượng toàn mạng nên hệ thống không cần phải nạp các phần mềm và quản lý trên các máy toàn mạng.

- Phát hiện được các cuộc tấn công mà HIDS bỏ qua: Khác với HIDS, NIDS kiểm tra header của tất cả các gói tin vì thế nó không bỏ sót các dấu hiệu xuất phát từ đây. Ví dụ: nhiều cuộc tấn công DoS, TearDrop (phân nhỏ) chỉ bị phát hiện khi xem header của các gói tin lưu chuyển trên mạng.

- Khó xóa bỏ dấu vết (evidence): Các thông tin lưu trong log file có thể bị kẻ đột nhập sửa đổi để che dấu các hoạt động xâm nhập, trong tình huống này HIDS khó có đủ thông tin để hoạt động. NIDS sử dụng lưu thông hiện hành trên mạng để phát hiện xâm nhập. Vì thế, kẻ đột nhập không thể xóa bỏ được các dấu vết tấn công. Các thông tin bắt

được không chỉ chứa cách thức tấn công mà cả thông tin hỗ trợ cho việc xác minh và buộc tội kẻ đột nhập.

- Phát hiện và đối phó kịp thời : NIDS phát hiện các cuộc tấn công ngay khi xảy ra, vì thế việc cảnh báo và đối phó có thể thực hiện được nhanh hơn. VD : Một hacker thực hiện tấn công DoS dựa trên TCP có thể bị NIDS phát hiện và ngăn chặn ngay bằng việc gửi yêu cầu TCP reset nhằm chấm dứt cuộc tấn công trước khi nó xâm nhập và phá vỡ máy bị hại.

- Có tính độc lập cao: Lỗi hệ thống không có ảnh hưởng đáng kể nào đối với công việc của các máy trên mạng. Chúng chạy trên một hệ thống chuyên dụng dễ dàng cài đặt; đơn thuần chỉ mở thiết bị ra, thực hiện một vài sự thay đổi cấu hình và cắm chúng vào trong mạng tại một vị trí cho phép nó kiểm soát các cuộc lưu thông nhạy cảm.

Nhược điểm

- Bị hạn chế với Switch: Nhiều lợi điểm của NIDS không phát huy được trong các mạng chuyển mạch hiện đại. Thiết bị switch chia mạng thành nhiều phân độc lập vì thế NIDS khó thu thập được thông tin trong toàn mạng. Do chỉ kiểm tra mạng trên đoạn mà nó trực tiếp kết nối tới, nó không thể phát hiện một cuộc tấn công xảy ra trên các đoạn mạng khác. Vấn đề này dẫn tới yêu cầu tổ chức cần phải mua một lượng lớn các bộ cảm biến để có thể bao phủ hết toàn mạng gây tốn kém về chi phí cài đặt.

- Hạn chế về hiệu năng: NIDS sẽ gặp khó khăn khi phải xử lý tất cả các gói tin trên mạng rộng hoặc có mật độ lưu thông cao, dẫn đến không thể phát hiện các cuộc tấn công thực hiện vào lúc "cao điểm". Một số nhà sản xuất đã khắc phục bằng cách cứng hoá hoàn toàn IDS nhằm tăng cường tốc độ cho nó. Tuy nhiên, do phải đảm bảo về mật tốc độ nên một số gói tin được bỏ qua có thể gây lỗ hổng cho tấn công xâm nhập.

- Tăng thông lượng mạng: Một hệ thống phát hiện xâm nhập có thể cần truyền một dung lượng dữ liệu lớn trở về hệ thống phân tích trung tâm, có nghĩa là một gói tin được kiểm soát sẽ sinh ra một lượng lớn tải phân tích. Để khắc phục người ta thường sử dụng các tiến trình giảm dữ liệu linh hoạt để giảm bớt số lượng các lưu thông được truyền tải. Họ cũng thường thêm các chu trình tự ra các quyết định vào các bộ cảm biến và sử dụng

các trạm trung tâm như một thiết bị hiển thị trạng thái hoặc trung tâm truyền thông hơn là thực hiện các phân tích thực tế. Điểm bất lợi là nó sẽ cung cấp rất ít thông tin liên quan cho các bộ cảm biến; bất kỳ bộ cảm biến nào sẽ không biết được việc một bộ cảm biến khác dò được một cuộc tấn công. Một hệ thống như vậy sẽ không thể dò được các cuộc tấn công hiệp đồng hoặc phức tạp.

- Một hệ thống NIDS thường gặp khó khăn trong việc xử lý các cuộc tấn công trong một phiên được mã hoá. Lỗi này càng trở nên trầm trọng khi nhiều công ty và tổ chức đang áp dụng mạng riêng ảo VPN.

- Một số hệ thống NIDS cũng gặp khó khăn khi phát hiện các cuộc tấn công mạng từ các gói tin phân mảnh. Các gói tin định dạng sai này có thể làm cho NIDS hoạt động sai và đổ vỡ.

1.2.5.2 Host based IDS – HIDS.

Host-based IDS tìm kiếm dấu hiệu của xâm nhập vào một host cục bộ; thường sử dụng các cơ chế kiểm tra và phân tích các thông tin được logging. Nó tìm kiếm các hoạt động bất thường như login, truy nhập file không thích hợp, bước leo thang các đặc quyền không được chấp nhận.

Kiến trúc IDS này thường dựa trên các luật (rule-based) để phân tích các hoạt động. Ví dụ đặc quyền của người sử dụng cấp cao chỉ có thể đạt được thông qua lệnh su-select user, như vậy những cố gắng liên tục để login vào account root có thể được coi là một cuộc tấn công.

Ưu điểm

- Xác định được kết quả của cuộc tấn công: Do HIDS sử dụng dữ liệu log lưu các sự kiện xảy ra, nó có thể biết được cuộc tấn công là thành công hay thất bại với độ chính xác cao hơn NIDS. Vì thế, HIDS có thể bổ sung thông tin tiếp theo khi cuộc tấn công được sớm phát hiện với NIDS.

- Giám sát được các hoạt động cụ thể của hệ thống: HIDS có thể giám sát các hoạt động mà NIDS không thể như: truy nhập file, thay đổi quyền, các hành động thực thi, truy nhập dịch vụ được phân quyền. Đồng thời nó cũng giám sát các hoạt động chỉ được

thực hiện bởi người quản trị. Vì thế, hệ thống host-based IDS có thể là một công cụ cực mạnh để phân tích các cuộc tấn công có thể xảy ra do nó thường cung cấp nhiều thông tin chi tiết và chính xác hơn một hệ network-based IDS.

- Phát hiện các xâm nhập mà NIDS bỏ qua: chẳng hạn kẻ đột nhập sử dụng bàn phím xâm nhập vào một server sẽ không bị NIDS phát hiện.

- Thích nghi tốt với môi trường chuyển mạch, mã hoá: Việc chuyển mạch và mã hoá thực hiện trên mạng và do HIDS cài đặt trên máy nên nó không bị ảnh hưởng bởi hai kỹ thuật trên.

- Không yêu cầu thêm phần cứng: Được cài đặt trực tiếp lên hạ tầng mạng có sẵn (FTP Server, WebServer) nên HIDS không yêu cầu phải cài đặt thêm các phần cứng khác.

Nhược điểm

- Khó quản trị : các hệ thống host-based yêu cầu phải được cài đặt trên tất cả các thiết bị đặc biệt mà bạn muốn bảo vệ. Đây là một khối lượng công việc lớn để cấu hình, quản lý, cập nhật.

- Thông tin nguồn không an toàn: một vấn đề khác kết hợp với các hệ thống host-based là nó hướng đến việc tin vào nhật ký mặc định và năng lực kiểm soát của server. Các thông tin này có thể bị tấn công và đột nhập dẫn đến hệ thống hoạt động sai, không phát hiện được xâm nhập.

- Hệ thống host-based tương đối đắt : nhiều tổ chức không có đủ nguồn tài chính để bảo vệ toàn bộ các đoạn mạng của mình sử dụng các hệ thống host-based. Những tổ chức đó phải rất thận trọng trong việc chọn các hệ thống nào để bảo vệ. Nó có thể để lại các lỗ hổng lớn trong mức độ bao phủ phát hiện xâm nhập. Ví dụ như một kẻ tấn công trên một hệ thống láng giềng không được bảo vệ có thể đánh hơi thấy các thông tin xác thực hoặc các tài liệu dễ bị xâm phạm khác trên mạng.

- Chiếm tài nguyên hệ thống: Do cài đặt trên các máy cần bảo vệ nên HIDS phải sử dụng các tài nguyên của hệ thống để hoạt động như: bộ vi xử lý, RAM, bộ nhớ ngoài.

1.2.6 Cơ chế hoạt động của hệ thống IDS/IPS.

Có hai cách tiếp cận cơ bản đối với việc phát hiện và phòng chống xâm nhập là :

- Phát hiện sự lạm dụng (Misuse Detection Model): Hệ thống sẽ phát hiện các xâm nhập bằng cách tìm kiếm các hành động tương ứng với các kỹ thuật xâm nhập đã được biết đến (dựa trên các dấu hiệu - signatures) hoặc các điểm dễ bị tấn công của hệ thống.

- Phát hiện sự bất thường (Anomaly Detection Model): Hệ thống sẽ phát hiện các xâm nhập bằng cách tìm kiếm các hành động khác với hành vi thông thường của người dùng hay hệ thống.

1.2.6.1 Mô hình phát hiện sự lạm dụng.

Phát hiện sự lạm dụng là phát hiện những kẻ xâm nhập đang cố gắng đột nhập vào hệ thống mà sử dụng một số kỹ thuật đã biết. Nó liên quan đến việc mô tả đặc điểm các cách thức xâm nhập vào hệ thống đã được biết đến, mỗi cách thức này được mô tả như một mẫu. Hệ thống phát hiện sự lạm dụng chỉ thực hiện kiểm soát đối với các mẫu đã rõ ràng. Mẫu có thể là một xâu bit cố định (ví dụ như một virus đặc tả việc chèn xâu),...dùng để mô tả một tập hay một chuỗi các hành động đáng nghi ngờ.

Ở đây, ta sử dụng thuật ngữ kịch bản xâm nhập (intrusion scenario). Một hệ thống phát hiện sự lạm dụng điển hình sẽ liên tục so sánh hành động của hệ thống hiện tại với một tập các kịch bản xâm nhập để cố gắng dò ra kịch bản đang được tiến hành. Hệ thống này có thể xem xét hành động hiện tại của hệ thống được bảo vệ trong thời gian thực hoặc có thể là các bản ghi kiểm tra được ghi lại bởi hệ điều hành.

Các kỹ thuật để phát hiện sự lạm dụng khác nhau ở cách thức mà chúng mô hình hoá các hành vi chỉ định một sự xâm nhập. Các hệ thống phát hiện sự lạm dụng thế hệ đầu tiên sử dụng các luật (rules) để mô tả những gì mà các nhà quản trị an ninh tìm kiếm trong hệ thống. Một lượng lớn tập luật được tích lũy dẫn đến khó có thể hiểu và sửa đổi bởi chúng không được tạo thành từng nhóm một cách hợp lý trong một kịch bản xâm nhập.

Để giải quyết khó khăn này, các hệ thống thế hệ thứ hai đưa ra các biểu diễn kịch bản xen kẽ, bao gồm các tổ chức luật dựa trên mô hình và các biểu diễn về phép biến đổi

trạng thái. Điều này sẽ mang tính hiệu quả hơn đối với người dùng hệ thống cần đến sự biểu diễn và hiểu rõ ràng về các kịch bản. Hệ thống phải thường xuyên duy trì và cập nhật để đương đầu với những kịch bản xâm nhập mới được phát hiện.

Do các kịch bản xâm nhập có thể được đặc tả một cách chính xác, các hệ thống phát hiện sự lạm dụng sẽ dựa theo đó để theo vết hành động xâm nhập. Trong một chuỗi hành động, hệ thống phát hiện có thể đoán trước được bước tiếp theo của hành động xâm nhập. Bộ dò tìm phân tích thông tin hệ thống để kiểm tra bước tiếp theo, và khi cần sẽ can thiệp để làm giảm bởi tác hại có thể.

1.2.6.2 Mô hình phát hiện sự bất thường.

Dựa trên việc định nghĩa và mô tả đặc điểm của các hành vi có thể chấp nhận của hệ thống để phân biệt chúng với các hành vi không mong muốn hoặc bất thường, tìm ra các thay đổi, các hành vi bất hợp pháp.

Như vậy, bộ phát hiện sự không bình thường phải có khả năng phân biệt giữa những hiện tượng thông thường và hiện tượng bất thường.

Ranh giới giữa dạng thức chấp nhận được và dạng thức bất thường của đoạn mã và dữ liệu lưu trữ được định nghĩa rõ ràng (chỉ cần một bit khác nhau), còn ranh giới giữa hành vi hợp lệ và hành vi bất thường thì khó xác định hơn.

Phát hiện sự không bình thường được chia thành hai loại tĩnh và động.

- Phát hiện tĩnh

Dựa trên giả thiết ban đầu là phần hệ thống được kiểm soát phải luôn luôn không đổi. Ở đây, ta chỉ quan tâm đến phần mềm của vùng hệ thống đó (với giả sử là phần cứng không cần phải kiểm tra). Phần tĩnh của một hệ thống bao gồm 2 phần con: mã hệ thống và dữ liệu của phần hệ thống đó. Hai thông tin này đều được biểu diễn dưới dạng một chuỗi bit nhị phân hoặc một tập các chuỗi. Nếu biểu diễn này có sự sai khác so với dạng thức gốc thì hoặc có lỗi xảy ra hoặc một kẻ xâm nhập nào đó đã thay đổi nó. Lúc này, bộ phát hiện tĩnh sẽ được thông báo để kiểm tra tính toàn vẹn dữ liệu.

Cụ thể là: bộ phát hiện tĩnh đưa ra một hoặc một vài chuỗi bit cố định để định nghĩa trạng thái mong muốn của hệ thống. Các chuỗi này giúp ta thu được một biểu diễn về trạng

thái đó, có thể ở dạng nén. Sau đó, nó so sánh biểu diễn trạng thái thu được với biểu diễn tương tự được tính toán dựa trên trạng thái hiện tại của cùng xâu bit cố định. Bất kỳ sự khác nhau nào đều là thể hiện lỗi như hỏng phần cứng hoặc có xâm nhập.

Biểu diễn trạng thái tĩnh có thể là các xâu bit thực tế được chọn để định nghĩa cho trạng thái hệ thống, tuy nhiên điều đó khá tốn kém về lưu trữ cũng như về các phép toán so sánh. Do vấn đề cần quan tâm là việc tìm ra được sự sai khác để cảnh báo xâm nhập chứ không phải chỉ ra sai khác ở đâu nên ta có thể sử dụng dạng biểu diễn được nén để giảm chi phí. Nó là giá trị tóm tắt tính được từ một xâu bit cơ sở. Phép tính toán này phải đảm bảo sao cho giá trị tính được từ các xâu bit cơ sở khác nhau là khác nhau. Có thể sử dụng các thuật toán checksums, message-digest (phân loại thông điệp), các hàm băm.

Một số bộ phát hiện xâm nhập kết hợp chặt chẽ với meta-data (dữ liệu mô tả các đối tượng dữ liệu) hoặc thông tin về cấu trúc của đối tượng được kiểm tra. Ví dụ, meta-data cho một log file bao gồm kích cỡ của nó. Nếu kích cỡ của log file tăng thì có thể là một dấu hiệu xâm nhập.

- Phát hiện động

Trước hết ta đưa ra khái niệm hành vi của hệ thống (behavior). Hành vi của hệ thống được định nghĩa là một chuỗi các sự kiện phân biệt, ví dụ như rất nhiều hệ thống phát hiện xâm nhập sử dụng các bản ghi kiểm tra (audit record), sinh ra bởi hệ điều hành để định nghĩa các sự kiện liên quan, trong trường hợp này chỉ những hành vi mà kết quả của nó là việc tạo ra các bản ghi kiểm tra của hệ điều hành mới được xem xét.

Các sự kiện có thể xảy ra theo trật tự nghiêm ngặt hoặc không và thông tin phải được tích lũy. Các ngưỡng được định nghĩa để phân biệt ranh giới giữa việc sử dụng tài nguyên hợp lý hay bất thường.

Nếu không chắc chắn hành vi là bất thường hay không, hệ thống có thể dựa vào các tham số được thiết lập trong suốt quá trình khởi tạo liên quan đến hành vi. Ranh giới trong trường hợp này là không rõ ràng do đó có thể dẫn đến những cảnh báo sai.

Cách thức thông thường nhất để xác định ranh giới là sử dụng các phân loại thống kê và các độ lệch chuẩn. Khi một phân loại được thiết lập, ranh giới có thể được vạch ra

nhờ sử dụng một số độ lệch chuẩn. Nếu hành vi nằm bên ngoài thì sẽ cảnh báo là có xâm nhập.

Cụ thể là: các hệ thống phát hiện động thường tạo ra một profile (dữ liệu) cơ sở để mô tả đặc điểm các hành vi bình thường, chấp nhận được. Một dữ liệu bao gồm tập các đo lường được xem xét về hành vi, mỗi đại lượng đo lường gồm nhiều chiều:

- + Liên quan đến các lựa chọn: thời gian đăng nhập, vị trí đăng nhập,...
- + Các tài nguyên được sử dụng trong cả quá trình hoặc trên một đơn vị thời gian: chiều dài phiên giao dịch, số các thông điệp gửi ra mạng trong một đơn vị thời gian,...
- + Chuỗi biểu diễn các hành động.

Sau khi khởi tạo dữ liệu cơ sở, quá trình phát hiện xâm nhập có thể được bắt đầu. Phát hiện động lúc này cũng giống như phát hiện tĩnh ở đó chúng kiểm soát hành vi bằng cách so sánh mô tả đặc điểm hiện tại về hành vi với mô tả ban đầu của hành vi được mong đợi (chính là dữ liệu cơ sở), để tìm ra sự khác nhau. Khi hệ thống phát hiện xâm nhập thực hiện, nó xem xét các sự kiện liên quan đến thực thể hoặc các hành động là thuộc tính của thực thể. Chúng xây dựng thêm một dữ liệu hiện tại.

Các hệ thống phát hiện xâm nhập thế hệ trước phải phụ thuộc vào các bản ghi kiểm tra (audit record) để bắt giữ các sự kiện hoặc các hành động liên quan. Các hệ thống sau này thì ghi lại một cơ sở dữ liệu đặc tả cho phát hiện xâm nhập. Một số hệ thống hoạt động với thời gian thực, hoặc gần thời gian thực, quan sát trực tiếp sự kiện trong khi chúng xảy ra hơn là đợi hệ điều hành tạo ra bản ghi mô tả sự kiện.

Khó khăn chính đối với các hệ thống phát hiện động là chúng phải xây dựng các dữ liệu cơ sở một cách chính xác, và sau đó nhận dạng hành vi sai trái nhờ các dữ liệu.

Các dữ liệu cơ sở có thể xây dựng nhờ việc giả chạy hệ thống hoặc quan sát hành vi người dùng thông thường qua một thời gian dài.

1.2.6.3 So sánh giữa 2 mô hình.

Bảng 1.1. So sánh 2 mô hình phát hiện sự lạm dụng và bất thường.

Phát hiện sự lạm dụng	Phát hiện sự bất thường
Bao gồm: - Cơ sở dữ liệu các dấu hiệu tấn công. - Tìm kiếm các so khớp mẫu đúng.	Bao gồm: - Cơ sở dữ liệu các hành động thông thường. - Tìm kiếm độ lệch của hành động thực tế so với hành động thông thường.
Hiệu quả trong việc phát hiện các dạng tấn công đã biết, hay các biến thể (thay đổi nhỏ) của các dạng tấn công đã biết. Không phát hiện được các dạng tấn công mới.	Hiệu quả trong việc phát hiện các dạng tấn công mới mà một hệ thống phát hiện sự lạm dụng bỏ qua.
Dễ cấu hình hơn do đòi hỏi ít hơn về thu thập dữ liệu, phân tích và cập nhật	Khó cấu hình hơn vì đưa ra nhiều dữ liệu hơn, phải có được một khái niệm toàn diện về hành vi đã biết hay hành vi được mong đợi của hệ thống
Đưa ra kết luận dựa vào phép so khớp mẫu (<i>pattern matching</i>).	Đưa ra kết quả dựa vào tương quan bằng thống kê giữa hành vi thực tế và hành vi được mong đợi của hệ thống (hay chính là dựa vào độ lệch giữa thông tin thực tế và ngưỡng cho phép).
Có thể kích hoạt một thông điệp cảnh báo nhờ một dấu hiệu chắc chắn, hoặc	Có thể hỗ trợ việc tự sinh thông tin hệ thống một cách tự động nhưng cần

cung cấp dữ liệu hỗ trợ cho các dấu hiệu khác.	có thời gian và dữ liệu thu thập được phải rõ ràng.
--	---

Để có được một hệ thống phát hiện xâm nhập tốt nhất ta tiến hành kết hợp cả hai phương pháp trên trong cùng một hệ thống. Hệ thống kết hợp này sẽ cung cấp khả năng phát hiện nhiều loại tấn công hơn và hiệu quả hơn.

CHƯƠNG 2: GIỚI THIỆU VỀ SNORT-INLINE

1.3 2.1. Tổng quan về snort.

2.1.1. Giới thiệu về snort.

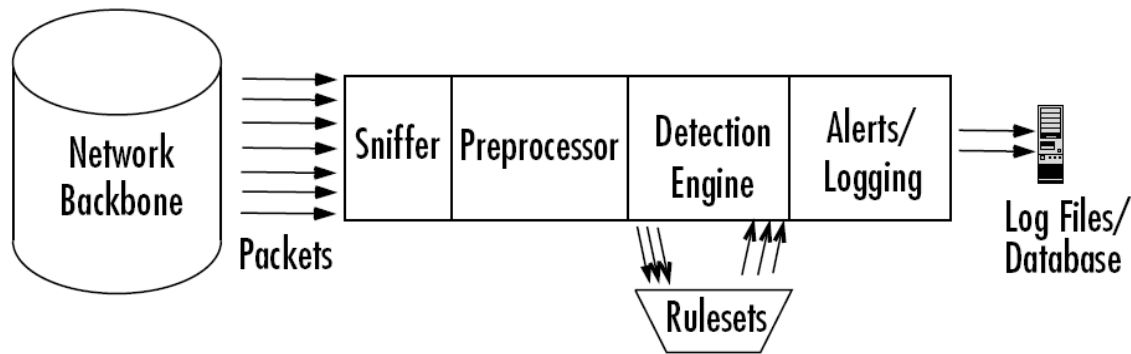
Snort là một NIDS được Martin Roesch phát triển dưới mô hình mã nguồn mở. Tuy Snort miễn phí nhưng nó lại có rất nhiều tính năng tuyệt vời mà không phải sản phẩm thương mại nào cũng có thể có được. Với kiến trúc thiết kế theo kiểu module, người dùng có thể tự tăng cường tính năng cho hệ thống Snort của mình bằng việc cài đặt hay viết thêm mới các module. Cơ sở dữ liệu luật của Snort đã lên tới 2930 luật và được cập nhật thường xuyên bởi một cộng đồng người sử dụng. Snort có thể chạy trên nhiều hệ thống nền như Windows, Linux, OpenBSD, FreeBSD, NetBSD, Solaris, HP-UX, AIX, IRIX, MacOS.

Bên cạnh việc có thể hoạt động như một ứng dụng thu bắt gói tin thông thường, Snort còn có thể được cấu hình để chạy như một NIDS. Snort hỗ trợ khả năng hoạt động trên các giao thức sau: Ethernet, 802.11, Token Ring, FDDI, Cisco HDLC, SLIP, PPP, và PF của OpenBSD.

2.1.2. Kiến trúc của snort.

Snort bao gồm nhiều thành phần, với mỗi phần có một chức năng riêng. Các phần chính đó là:

- Module giải mã gói tin (Packet Decoder)
- Module tiền xử lý (Preprocessors)
- Module phát hiện (Detection Engine)
- Module log và cảnh báo (Logging and Alerting System)
- Module kết xuất thông tin (Output Module)
- Kiến trúc của Snort được mô tả trong hình sau:



Hình 2.1. Mô hình kiến trúc hệ thống snort.

Khi Snort hoạt động nó sẽ thực hiện việc lắng nghe và thu bắt tất cả các gói tin nào di chuyển qua nó. Các gói tin sau khi bị bắt được đưa vào Module Giải mã gói tin. Tiếp theo gói tin sẽ được đưa vào module Tiền xử lý, rồi module Phát hiện. Tại đây tùy theo việc có phát hiện được xâm nhập hay không mà gói tin có thể được bỏ qua để lưu thông tiếp hoặc được đưa vào module Log và cảnh báo để xử lý. Khi các cảnh báo được xác định module Kết xuất thông tin sẽ thực hiện việc đưa cảnh báo ra theo đúng định dạng mong muốn. Sau đây ta sẽ đi sâu vào chi tiết hơn về cơ chế hoạt động và chức năng của từng thành phần.

2.1.2.1. Module giải mã gói tin.

Snort sử dụng thư viện pcap để bắt mọi gói tin trên mạng lưu thông qua hệ thống. Sau đó phân tích những gói tin bắt được để lấy những thông tin hữu ích như những cổng và những địa chỉ... Snort sẽ cảnh báo nếu nó tìm thấy những header không đúng cấu trúc, chiều dài TCP bất thường...

Một gói tin sau khi được giải mã sẽ được đưa tiếp vào module tiền xử lý.

2.1.2.2. Module tiền xử lý.

Module tiền xử lý là một module rất quan trọng đối với bất kỳ một hệ thống IDS nào để có thể chuẩn bị gói dữ liệu đưa vào cho module phát hiện phân tích. Ba nhiệm vụ chính của các module loại này là:

- + Kết hợp lại các gói tin: Khi một lượng dữ liệu lớn được gửi đi, thông tin sẽ không đóng gói toàn bộ vào một gói tin mà phải thực hiện việc phân mảnh, chia gói tin ban đầu

thành nhiều gói tin rồi mới gửi đi. Khi Snort nhận được các gói tin này nó phải thực hiện việc ghép nối lại để có được dữ liệu nguyên dạng ban đầu, từ đó mới thực hiện được các công việc xử lý tiếp. Như ta đã biết khi một phiên làm việc của hệ thống diễn ra, sẽ có rất nhiều gói tin được trao đổi trong phiên đó. Một gói tin riêng lẻ sẽ không có trạng thái và nếu công việc phát hiện xâm nhập chỉ dựa hoàn toàn vào gói tin đó sẽ không đem lại hiệu quả cao. Module tiền xử lý stream giúp Snort có thể hiểu được các phiên làm việc khác nhau (nói cách khác đem lại tính có trạng thái cho các gói tin) từ đó giúp đạt được hiệu quả cao hơn trong việc phát hiện xâm nhập.[8]

+ Giải mã và chuẩn hóa giao thức (decode/normalize): công việc phát hiện xâm nhập dựa trên dấu hiệu nhận dạng nhiều khi bị thất bại khi kiểm tra các giao thức có dữ liệu có thể được thể hiện dưới nhiều dạng khác nhau.

Ví dụ: một web server có thể chấp nhận nhiều dạng URL như URL được viết dưới dạng mã hexa/Unicode, URL chấp nhận cả dấu \ hay / hoặc nhiều ký tự này liên tiếp cùng lúc. Chẳng hạn ta có dấu hiệu nhận dạng “scripts/iisadmin”, kẻ tấn công có thể vượt qua được bằng cách tùy biến các yêu cầu gửi đến web server như sau:

“scripts/./iisadmin”

“scripts/examples/./iisadmin”

“scripts\iisadmin”

“scripts/.\iisadmin”

Hoặc thực hiện việc mã hóa các chuỗi này dưới dạng khác.

Nếu Snort chỉ thực hiện đơn thuần việc so sánh dữ liệu với dấu hiệu nhận dạng sẽ xảy ra tình trạng bỏ sót các hành vi xâm nhập. Do vậy, một số module tiền xử lý của Snort phải có nhiệm vụ giải mã và chỉnh sửa, sắp xếp lại các thông tin đầu vào này để thông tin khi đưa đến module phát hiện có thể phát hiện được mà không bỏ sót. Hiện nay Snort đã hỗ trợ việc giải mã và chuẩn hóa cho các giao thức: telnet, http, rpc, arp.

Phát hiện các xâm nhập bất thường (nonrule /anormal): các plugin tiền xử lý dạng này thường dùng để đối phó với các xâm nhập không thể hoặc rất khó phát hiện được bằng các luật thông thường hoặc các dấu hiệu bất thường trong giao thức. Các module

tiền xử lý dạng này có thể thực hiện việc phát hiện xâm nhập theo bất cứ cách nào mà ta nghĩ ra từ đó tăng cường thêm tính năng cho Snort.

Ví dụ: Một plugin tiền xử lý có nhiệm vụ thống kê thông lượng mạng tại thời điểm bình thường để rồi khi có thông lượng mạng bất thường xảy ra nó có thể tính toán, phát hiện và đưa ra cảnh báo (phát hiện xâm nhập theo mô hình thống kê).

Phiên bản hiện tại của Snort có đi kèm hai plugin giúp phát hiện các xâm nhập bất thường đó là portscan và bo (backoffice). Portcan dùng để đưa ra cảnh báo khi kẻ tấn công thực hiện việc quét các cổng của hệ thống để tìm lỗ hổng. Bo dùng để đưa ra cảnh báo khi hệ thống đã bị nhiễm trojan backoffice và kẻ tấn công từ xa kết nối tới backoffice thực hiện các lệnh từ xa.

2.1.2.3. Module phát hiện.

Đây là module quan trọng nhất của Snort. Nó chịu trách nhiệm phát hiện các dấu hiệu xâm nhập. Module phát hiện sử dụng các luật được định nghĩa trước để so sánh với dữ liệu thu thập được từ đó xác định xem có xâm nhập xảy ra hay không. Rồi tiếp theo mới có thể thực hiện một số công việc như ghi log, tạo thông báo và kết xuất thông tin.

Một vấn đề rất quan trọng trong module phát hiện là vấn đề thời gian xử lý các gói tin: một IDS thường nhận được rất nhiều gói tin và bản thân nó cũng có rất nhiều các luật xử lý. Có thể mất những khoảng thời gian khác nhau cho việc xử lý các gói tin khác nhau. Và khi thông lượng mạng quá lớn có thể xảy ra việc bỏ sót hoặc không phản hồi được đúng lúc. Khả năng xử lý của module phát hiện dựa trên một số yếu tố như: số lượng các luật, tốc độ của hệ thống đang chạy Snort, tải trên mạng. Một số thử nghiệm cho biết, phiên bản hiện tại của Snort khi được tối ưu hóa chạy trên hệ thống có nhiều bộ vi xử lý và cấu hình máy tính tương đối mạnh thì có thể hoạt động tốt trên cả các mạng cỡ Giga.

Một module phát hiện cũng có khả năng tách các phần của gói tin ra và áp dụng các luật lên từng phần nào của gói tin đó. Các phần đó có thể là:

- IP header
- Header ở tầng giao vận: TCP, UDP

- Header ở tầng ứng dụng: DNS header, HTTP header, FTP header, ...
- Phần tải của gói tin (bạn cũng có thể áp dụng các luật lên các phần dữ liệu được truyền đi của gói tin)

Một vấn đề nữa trong Module phát hiện đó là việc xử lý thế nào khi một gói tin bị phát hiện bởi nhiều luật. Do các luật trong Snort cũng được đánh thứ tự ưu tiên, nên một gói tin khi bị phát hiện bởi nhiều luật khác nhau, cảnh báo được đưa ra sẽ là cảnh báo ứng với luật có mức ưu tiên lớn nhất.

2.1.2.4. Module log và cảnh báo.

Tùy thuộc vào việc module phát hiện có nhận dạng được xâm nhập hay không mà gói tin có thể bị ghi log hoặc đưa ra cảnh báo. Các file log là các file text dữ liệu trong đó có thể được ghi dưới nhiều định dạng khác nhau chẳng hạn tcp dump.

2.1.2.5. Module kết xuất thông tin.

Mô đun này có thể thực hiện các thao tác khác nhau tùy theo việc bạn muốn lưu kết quả xuất ra như thế nào. Tùy theo việc cấu hình hệ thống mà nó có thể thực hiện các công việc như là:

- Ghi log file
- Ghi syslog: syslog và một chuẩn lưu trữ các file log được sử dụng rất nhiều trên các hệ thống Unix, Linux.
- Ghi cảnh báo vào cơ sở dữ liệu.
- Tạo file log dạng xml: việc ghi log file dạng xml rất thuận tiện cho việc trao đổi và chia sẻ dữ liệu.
- Cấu hình lại Router, firewall.
- Gửi các cảnh báo được gói trong gói tin sử dụng giao thức SNMP. Các gói tin dạng SNMP này sẽ được gửi tới một SNMP server từ đó giúp cho việc quản lý các cảnh báo và hệ thống IDS một cách tập trung và thuận tiện hơn.
- Gửi các thông điệp SMB (Server Message Block) tới các máy tính Windows. Nếu không hài lòng với các cách xuất thông tin như trên, ta có thể viết các mô đun kết xuất thông tin riêng tùy theo mục đích sử dụng.

2.1.3. Bộ luật của snort.

2.1.3.1. Giới thiệu.

Cũng giống như virus, hầu hết các hoạt động tấn công hay xâm nhập đều có các dấu hiệu riêng. Các thông tin về các dấu hiệu này sẽ được sử dụng để tạo nên các luật cho Snort. Thông thường, các bẫy (honey pots) được tạo ra để tìm hiểu xem các kẻ tấn công làm gì cũng như các thông tin về công cụ và công nghệ chúng sử dụng. Và ngược lại, cũng có các cơ sở dữ liệu về các lỗ hổng bảo mật mà những kẻ tấn công muốn khai thác. Các dạng tấn công đã biết này được dùng như các dấu hiệu để phát hiện tấn công xâm nhập. Các dấu hiệu đó có thể xuất hiện trong phần header của các gói tin hoặc nằm trong phần nội dung của chúng. Hệ thống phát hiện của Snort hoạt động dựa trên các luật (rules) và các luật này lại được dựa trên các dấu hiệu nhận dạng tấn công. Các luật có thể được áp dụng cho tất cả các phần khác nhau của một gói tin dữ liệu.

Một luật có thể được sử dụng để tạo nên một thông điệp cảnh báo, log một thông điệp hay có thể bỏ qua một gói tin.

2.1.3.2 Cấu trúc luật của snort.

Cấu trúc một luật của snort có dạng như sau:

Rule Header	Rule Option
-------------	-------------

Hình 2.2. Cấu trúc luật của snort.

Diễn giải:

Tất cả các Luật của Snort về logic đều gồm 2 phần: Phần header và phần Option.

- Phần Header chứa thông tin về hành động mà luật đó sẽ thực hiện khi phát hiện ra có xâm nhập nằm trong gói tin và nó cũng chứa các tiêu chuẩn để áp dụng luật với gói tin đó.
- Phần Option chứa một thông điệp cảnh báo và các thông tin về các phần của gói tin dùng để tạo nên cảnh báo. Phần Option chứa các tiêu chuẩn phụ thêm để đối sánh luật

với gói tin. Một luật có thể phát hiện được một hay nhiều hoạt động thăm dò hay tấn công. Các luật thông minh có khả năng áp dụng cho nhiều dấu hiệu xâm nhập.

a. Phần Header.

Dưới đây là cấu trúc chung của phần Header của một luật Snort:

Action	Protocol	Address	Port	Direction	Address	Port
--------	----------	---------	------	-----------	---------	------

Hình 2.3. Header luật của Snort.

- Action: là phần qui định loại hành động nào được thực thi khi các dấu hiệu của gói tin được nhận dạng chính xác bằng luật đó. Thông thường, các hành động tạo ra một cảnh báo hoặc log thông điệp hoặc kích hoạt một luật khác.

- Protocol: là phần qui định việc áp dụng luật cho các packet chỉ thuộc một giao thức cụ thể nào đó. Ví dụ như IP, TCP, UDP ...

- Address: là phần địa chỉ nguồn và địa chỉ đích. Các địa chỉ có thể là một máy đơn, nhiều máy hoặc của một mạng nào đó. Trong hai phần địa chỉ trên thì một sẽ là địa chỉ nguồn, một sẽ là địa chỉ đích và địa chỉ nào thuộc loại nào sẽ do phần Direction “->” qui định.

- Port: xác định các cổng nguồn và đích của một gói tin mà trên đó luật được áp dụng.

- Direction: phần này sẽ chỉ ra đâu là địa chỉ nguồn, đâu là địa chỉ đích.

b. Phần Option.

Phần Rule Option nằm ngay sau phần Rule Header và được bao bọc trong dấu ngoặc đơn. Nếu có nhiều option thì các option sẽ được phân cách với nhau bằng dấu chấm phẩy ”;”. Nếu nhiều option được sử dụng thì các option này phải đồng thời được thỏa mãn tức là theo logic các option này liên kết với nhau bằng AND.

Mọi option được định nghĩa bằng các từ khoá. Một số các option còn chứa các tham số. Nói chung một option gồm 2 phần: một từ khoá và một tham số, hai phần này phân cách nhau bằng dấu hai chấm.

Ví dụ :

msg: “Detected confidented”;

msg là từ khoá còn “Detected confidented” là tham số.

Sau đây là chi tiết một số các option của luật Snort.

Từ khoá ack

Trong header TCP có chứa trường Acknowledgement Number với độ dài 32 bit. Trường này có ý nghĩa là chỉ ra số thứ tự tiếp theo gói tin TCP của bên gửi đang được chờ để nhận. Trường này chỉ có ý nghĩa khi mà cờ ACK được thiết lập.

Các công cụ như Nmap sử dụng đặc điểm này ping một máy. Ví dụ, nó có thể gửi một gói tin TCP tới cổng 80 với cờ ACK được bật và số thứ tự là 0. Bởi vậy, bên nhận sẽ thấy gói tin không hợp lệ và sẽ gửi trở lại gói tin RST. Khi mà Nmap nhận được gói tin RST thì tức là địa chỉ đích đang “sống”. Phương pháp này vẫn làm việc tốt đối với các máy không trả lời gói tin thuộc dạng ping ICMP ECHO REQUEST.

Vậy để kiểm tra loại ping TCP này thì ta có thể dùng luật như sau:

```
alert tcp any any -> 192.168.1.0/24 any (flags: A; ack: 0; msg: “TCP ping detected”)
```

Từ khoá classtype

Các luật có thể được phân loại và gán cho một số chỉ độ ưu tiên nào đó để nhóm và phân biệt chúng với nhau. Để hiểu rõ hơn về từ khoá này ta đầu tiên phải hiểu được file classification.config (được bao gồm trong file snort.conf sử dụng từ khoá include). Mỗi dòng trong file classification.config có cú pháp như sau:

```
config classification: name, description, priority
```

Trong đó:

- name: là tên dùng để phân loại, tên này sẽ được dùng với từ khoá classtype trong các luật Snort.

- description: mô tả về loại lớp này

- priority: là một số chỉ độ ưu tiên mặc định của lớp này. Độ ưu tiên này có thể được điều chỉnh trong từ khoá priority của phần option trong luật của Snort.

Ví dụ :

config classification: DoS , Denial of Service Attack, 2

và trong luật:

```
alert udp any any -> 192.168.1.0/24 6838 (msg:"DoS"; content: "server";  
classtype: DoS;)
```

```
alert udp any any -> 192.168.1.0/24 6838 (msg:"DoS"; content: "server";  
classtype: DoS; priority: 1;)
```

Trong câu lệnh thứ 2 thì ta đã ghi đè lên giá trị priority mặc định của lớp đã định nghĩa.

Từ khoá content

Một đặc tính quan trọng của Snort là nó có khả năng tìm một mẫu dữ liệu bên trong một gói tin. Mẫu này có thể dưới dạng chuỗi ASCII hoặc là một chuỗi nhị phân dưới dạng các kí tự hệ 16. Giống như virus, các tấn công cũng có các dấu hiệu nhận dạng và từ khoá content này dùng để tìm các dấu hiệu đó bên trong gói tin.

Ví dụ:

```
alert tcp 192.168.1.0/24 any -> ![192.168.1.0/24] any (content: "GET"; msg: "GET  
match");)
```

Luật trên tìm mẫu "GET" trong phần dữ liệu của tất cả các gói tin TCP có nguồn đi từ mạng 192.168.1.0/24 và đi đến các địa chỉ không thuộc mạng đó. Từ "GET" này rất hay được dùng trong các tấn công HTTP.

Một luật khác cũng thực hiện đúng nhiệm vụ giống như lệnh trên nhưng mẫu dữ liệu lại dưới dạng hệ 16 là:

```
alert tcp 192.168.1.0/24 any -> ![192.168.1.0/24] any (content: "|47 45 54|"; msg:  
"GET match");)
```

Đề ý rằng số 47 ở hệ 16 chính là bằng kí tự ASCII : G và tương tự 45 là E và 54 là T. Ta có thể dùng cả hai dạng trên trong cùng một luật nhưng nhớ là phải để dạng thập lục phân giữa cặp kí tự ||.

Tuy nhiên khi sử dụng từ khoá content ta cần nhớ rằng:

Đối sánh nội dung sẽ phải xử lý tính toán rất lớn và ta phải hết sức cân nhắc khi sử dụng nhiều luật có đối sánh nội dung.

Ta có thể sử dụng nhiều từ khoá content trong cùng một luật để tìm nhiều dấu hiệu trong cùng một gói tin.

Đối sánh nội dung là công việc rất nhạy cảm.

Có 3 từ khoá khác hay được dùng cùng với từ khoá content dùng để bổ sung thêm các điều kiện để tìm kiếm là :

- offset: dùng để xác định vị trí bắt đầu tìm kiếm (chuỗi chứa trong từ khoá content) là offset tính từ đầu phần dữ liệu của gói tin. Ví dụ sau sẽ tìm chuỗi “HTTP” bắt đầu từ vị trí cách đầu đoạn dữ liệu của gói tin là 4 byte:

```
alert tcp 192.168.1.0/24 any -> any any (content: “HTTP”; offset: 4; msg: “HTTP matched”);
```

- dept : dùng để xác định vị trí mà từ đó Snort sẽ dừng việc tìm kiếm. Từ khoá này cũng thường được dùng chung với từ khoá offset vừa nêu trên.

Ví dụ:

```
alert tcp 192.168.1.0/24 any -> any any (content: “HTTP”; offset: 4; dept: 40; msg: “HTTP matched”);
```

- Từ khoá này sẽ giúp cho việc tiêu tốn thời gian tìm kiếm khi mà đoạn dữ liệu trong gói tin là khá lớn.

- content-list: được sử dụng cùng với một file. Tên file (được chỉ ra trong phần tham số của từ khoá này) là một file text chứa danh sách các chuỗi cần tìm trong phần dữ liệu của gói tin. Mỗi chuỗi nằm trên một dòng riêng biệt.

Ví dụ như file test có dạng như sau:

“test”

“Snort”

“NIDS”

và ta có luật sau:

alert tcp 192.168.1.0/24 any -> any any (content-list: “test”;msg: “This is my Test”);).

Ta cũng có thể dùng kí tự phủ định ! trước tên file để cảnh báo đối với các gói tin không tìm thấy một chuỗi nào trong file đó.

Từ khoá dsize

Dùng để đối sánh theo chiều dài của phần dữ liệu. Rất nhiều tấn công sử dụng lỗi tràn bộ đệm bằng cách gửi các gói tin có kích thước rất lớn. Sử dụng từ khoá này, ta có thể so sánh độ lớn của phần dữ liệu của gói tin với một số nào đó.

alert ip any any -> 192.168.1.0/24 any (dsize: > 6000; msg: “Goi tin co kích thước lớn”);)

Từ khoá flags

Từ khoá này được dùng để phát hiện xem những bit cờ flag nào được bật (thiết lập) trong phần TCP header của gói tin. Mỗi cờ có thể được sử dụng như một tham số trong từ khoá flags. Sau đây là một số các cờ sử dụng trong từ khoá flags:

Bảng 2.1. Các cờ sử dụng với từ khoá flags.

Flag	Kí tự tham số dùng trong luật của Snort
FIN (Finish Flag)	F
SYN – Sync Flag	S
RST – Reset Flag	R
PSH – Push Flag	P
ACK – Acknowledge Flag	A
URG – Urgent Flag	U

Reserved Bit 1	1
Reserved Bit 2	2
No Flag set	0

Ta có thể sử dụng các dấu +, * và ! để thực hiện các phép toán logic AND, OR và NOT trên các bit cờ muốn kiểm tra. Ví dụ luật sau đây sẽ phát hiện một hành động quét dùng gói tin TCP SYN-FIN:

```
alert tcp any any -> 192.168.1.0/24 any (flags: SF; msg: "SYN-FIN packet detected");)
```

Từ khoá fragbits

Phần IP header của gói tin chứa 3 bit dùng để chống phân mảnh và tổng hợp các gói tin IP. Các bit đó là:

- Reserved Bit (RB) dùng để dành cho tương lai.
- Don't Fragment Bit (DF): nếu bit này được thiết lập thì tức là gói tin đó không bị phân mảnh.
- More Fragments Bit (MF): nếu được thiết lập thì tức là các phần khác (gói tin bị phân mảnh) của gói tin vẫn đang còn trên đường đi mà chưa tới đích. Nếu bit này không được thiết lập thì có nghĩa là đây là phần cuối cùng của gói tin (hoặc là gói duy nhất). Điều này xuất phát từ nguyên nhân: Nơi gửi đi phải chia gói tin IP thành nhiều đoạn nhỏ do phụ thuộc vào Đơn vị truyền dữ liệu lớn nhất cho phép (Maximum Transfer Units - MTU) trên đường truyền. Kích thước của gói tin không được phép vượt quá kích thước lớn nhất này. Do vậy, bit MF này giúp bên đích có thể tổng hợp lại các phần khác nhau thành một gói tin hoàn chỉnh.

Đôi khi các bit này bị các hacker sử dụng để tấn công và khai thác thông tin trên mạng của ta. Ví dụ, bit DF có thể được dùng để tìm MTU lớn nhất và nhỏ nhất trên đường đi từ nguồn xuất phát đến đích đến.

Sử dụng fragbits, ta có thể kiểm tra xem các bit trên có được thiết lập hay không. Ví dụ luật sau sẽ phát hiện xem bit DF trong gói tin ICMP có được bật hay không:

alert icmp any any -> 192.168.1.0/24 any (fragbits: D; msg: “Dont Fragment bit set”);)

Trong luật này , D dùng cho bit DF, R cho bit dự trữ và M cho bit MF. Ta cũng có thể dùng dấu phủ định ! trong luật này để kiểm tra khi bit không được bật:

alert icmp any any -> 192.168.1.0/24 any (fragbits: !D; msg: “Dont Fragment bit not set”);)

2.1.4. Cơ chế ngăn chặn của snort: snort – inline.

2.1.4.1 Tích hợp khả năng ngăn chặn vào snort.

Snort-inline là một nhánh phát triển của Snort do William Metcalf khởi xướng và lãnh đạo. Đến phiên bản 2.3.0 RC1 của Snort, inline-mode đã được tích hợp vào bản chính thức do snort.org phát hành. Sự kiện này đã biến Snort từ một IDS thuần túy trở thành một hệ thống có các khả năng của một IPS, mặc dù chế độ này vẫn chỉ là tùy chọn chứ không phải mặc định.

Ý tưởng chính của inline-mode là kết hợp khả năng ngăn chặn của iptables vào bên trong snort. Điều này được thực hiện bằng cách thay đổi môđun phát hiện và môđun xử lý cho phép snort tương tác với iptables. Cụ thể, việc chặn bắt các gói tin trong Snort được thực hiện thông qua Netfilter và thư viện libpcap sẽ được thay thế bằng việc sử dụng ipqueue và thư viện libipq. Hành động ngăn chặn của snort-inline sẽ được thực hiện bằng devel-mode của iptables.

2.1.4.2 Những bổ sung cho cấu trúc luật của snort hỗ trợ inline mode.

Để hỗ trợ tính năng ngăn chặn của Snort-inline, một số thay đổi và bổ sung đã được đưa vào bộ luật Snort. Đó là đưa thêm 3 hành động DROP, SDROP, INJECT và thay đổi trình tự ưu tiên của các luật trong Snort.

- DROP

Hành động DROP yêu cầu iptables loại bỏ gói tin và ghi lại thông tin như hành động LOG.

- SDROP

Hành động SDROP cũng tương tự như hành động DROP, điều khác biệt là ở chỗ Snort sẽ không ghi lại thông tin như hành động LOG.

- REJECT

Hành động REJECT yêu cầu iptables từ chối gói tin, có nghĩa là iptables sẽ loại bỏ và gửi lại một thông báo cho nguồn gửi gói tin đó. Hành động REJECT không ghi lại bất cứ thông tin gì.

Trình tự ưu tiên của các luật

- Trong các phiên bản gốc, trình tự ưu tiên của các hành động trong Snort là :

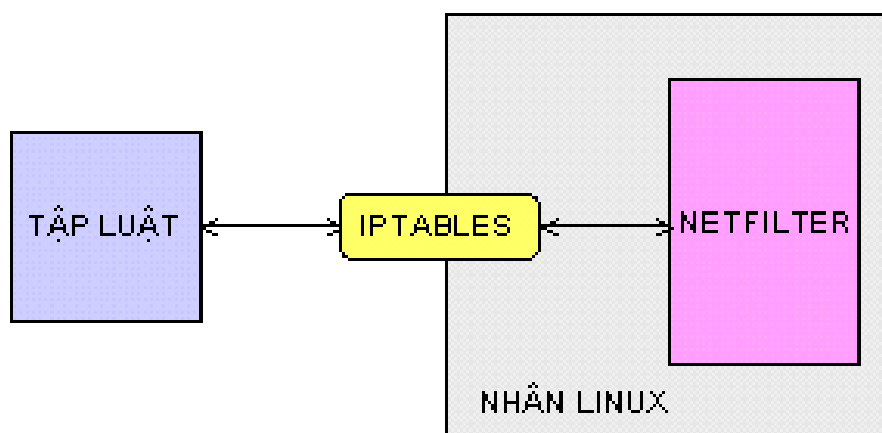
activation->dynamic-> alert->pass->log

- Trong inline-mode, trình tự ưu tiên này được thay đổi như sau :

activation->dynamic->pass->drop->sdrop->reject->alert->log

2.2. Giới thiệu về Iptables.

Iptables là một tường lửa ứng dụng lọc gói dữ liệu rất mạnh, miễn phí và có sẵn trên Linux. Netfilter/Iptables gồm 2 phần là Netfilter ở trong nhân Linux và Iptables nằm ngoài nhân. Iptables chịu trách nhiệm giao tiếp giữa người dùng và Netfilter để đẩy các luật của người dùng vào cho Netfilter xử lý. Netfilter tiến hành lọc các gói dữ liệu ở mức IP. Netfilter làm việc trực tiếp trong nhân, nhanh và không làm giảm tốc độ của hệ thống.



Hình 2.4. Sơ đồ Netfilter/Iptables

2.2.1 Cơ chế xử lý package trong IPTables.

Tất cả gói đi qua một chuỗi được xây dựng trong các bảng (hàng đợi) để xử lý.

Iptables được chia làm 3 bảng:

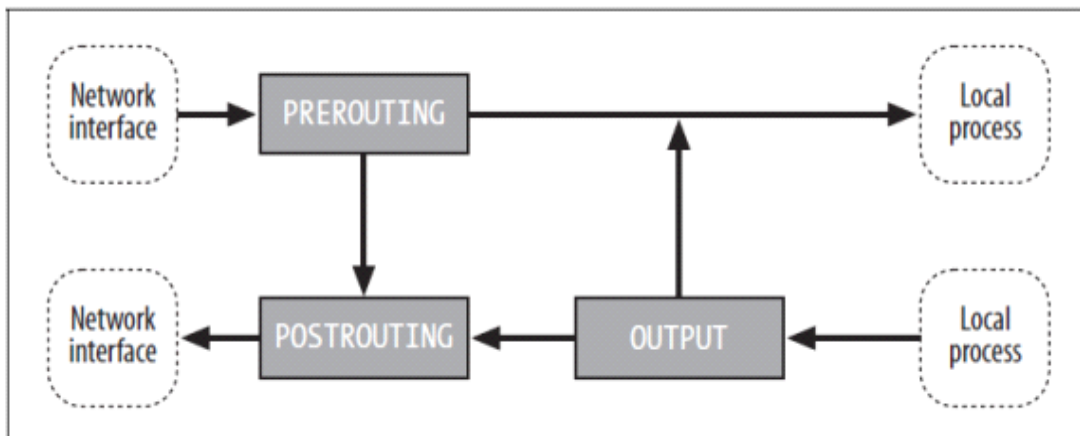
2.2.1.1 NAT table.

NAT table: thực thi chức năng NAT (Network Address Translation), bao gồm ba loại built-in chains sau đây:

- + Pre-routing chain: NAT từ ngoài vào trong nội bộ. Quá trình NAT sẽ thực hiện trước khi thực thi cơ chế routing. Điều này thuận lợi cho việc đổi địa chỉ đích để địa chỉ tương thích với bảng định tuyến của firewall, khi cấu hình ta có thể dùng khóa DNAT để mô tả kỹ thuật này.

- + Post-routing chain: NAT từ trong ra ngoài. Quá trình NAT sẽ thực hiện sau khi thực hiện cơ chế định tuyến. Quá trình này nhằm thay đổi địa chỉ nguồn của gói tin. Kỹ thuật này được gọi là NAT one-to-one hoặc many-to-one, được gọi là Source NAT hay SNAT.[2]

- + OUTPUT: Trong loại này firewall thực hiện quá trình NAT.

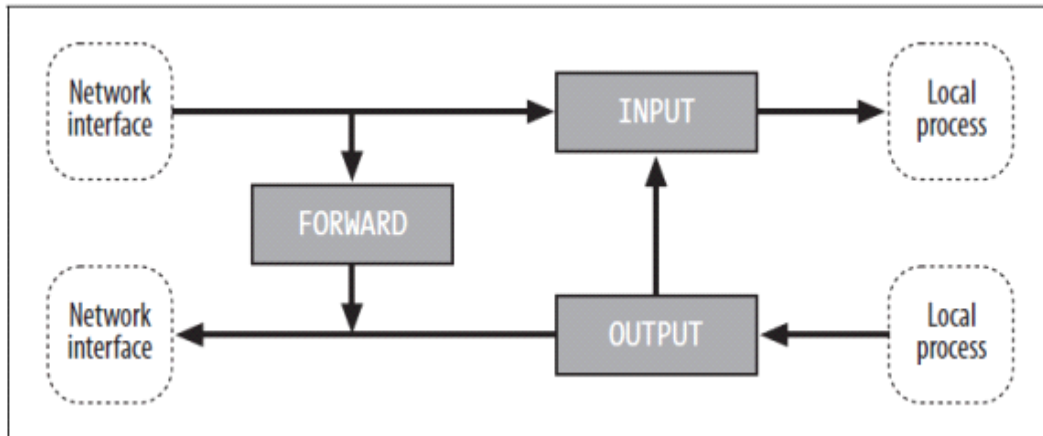


Hình 2.5. Quá trình xử lý gói tin trong bảng NAT.

2.2.1.2 Filter table.

Filter table: chịu trách nhiệm thiết lập bộ lọc packet (packet filtering), có ba loại built-in chains :

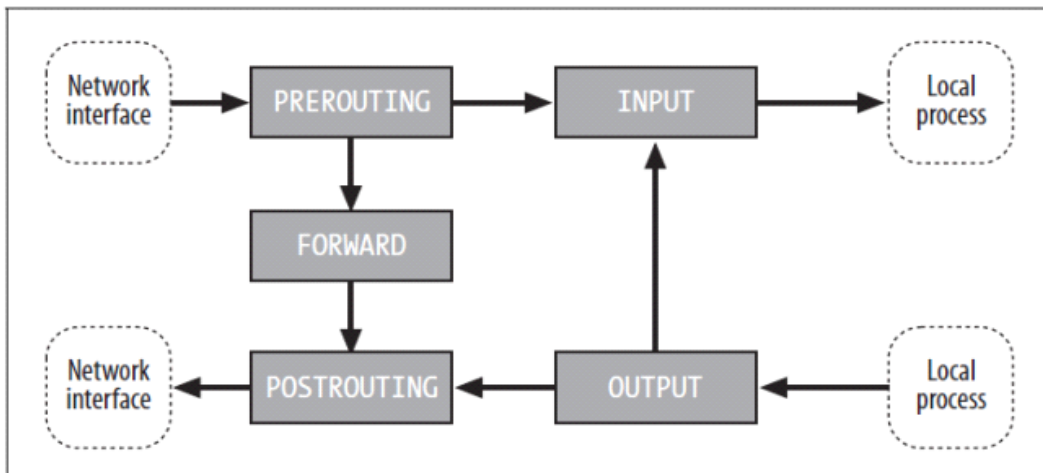
- Forward chain: Cho phép packet nguồn chuyển qua firewall.
- Input chain: Cho phép những gói tin đi vào từ firewall.
- Output chain: Cho phép những gói tin đi ra từ firewall.



Hình 2.6. Quá trình xử lý gói tin trong bảng Filter.

2.2.1.3 Mangle table.

Mangle table: Chịu trách nhiệm biến đổi quality of service bits trong TCP header.



Hình 2.7. Quá trình xử lý gói tin trong bảng Mangle

2.2.2 Một số khái niệm trong IPTables.

- **Chain** : là một chuỗi bao gồm nhiều Rule ,mặc định các bảng có sẵn các chain như INPUT , OUTPUT...
- **Rule** : là các luật đưa ra các điều kiện so sánh , tập hợp nhiều rule tạo thành Chain

- **Jump** :là cơ chế chuyển một packet đến một target nào đó để xử lý thêm một số thao tác khác.

- **Target** : là quá trình xử lý khi các gói tin đủ điều kiện. Các target được xây dựng sẵn trong iptables như:

- + ACCEPT: chấp nhận chuyển gói tin đi qua.
- + DROP: chặn những gói tin.
- + REJECT: chặn những gói tin và báo lại cho người gửi
- + DNAT: thay đổi địa chỉ đích của gói tin
- + SNAT: thay đổi địa chỉ nguồn của gói tin
- + MASQUERADING: là một kỹ thuật đặc biệt của SNAT (Many to One NAT).[2]

2.2.3 Các kiểu chặn trong IPtables.

2.2.3.1 Chặn theo giao thức.

Chặn theo giao thức : Dựa trên giao thức TCP , UDP và các port

Bảng 2.2. Tùy chọn chặn theo giao thức trong IPtables.

Sử dụng với tùy chọn -p tcp hoặc - udp	Giải thích
--sport <port>	Địa chỉ nguồn : có thể là một port hoặc một dải port start-portnumber:end-portnumber
--dport <port>	Địa chỉ đích : có thể là một port hoặc một dải port start-portnumber:end-portnumber

<code>--syn</code> (chỉ sử dụng cho <i>-p tcp</i>)	Sử dụng để xác định yêu cầu thiết lập connection mới
--	--

Ví dụ :

```
# iptables -A FORWARD -s 0/0 -i eth0 -d 192.168.1.58 -o eth1 -p TCP  
-sport 1024:65535 -dport 80 -j ACCEPT
```

Trong ví dụ này cho phép chuyển các gói tin đi vào từ interface eth0 và ra interface eth1 có địa chỉ nguồn bất kỳ và địa chỉ đích là 192.168.1.58 với giao thức TCP có port nguồn từ 1024 đến 65535 và port đích là 80 (http).

2.2.3.2 Chặn gói ICMP (Ping).

Bảng 2.3. Tùy chọn chặn gói ICMP trong IPtables.

Sử dụng với tùy chọn <i>---icmp-type</i>	Giải thích
<code>--icmp-type <type></code>	Sử dụng với các tùy chọn thông dụng như : echo-reply và echo-request

Ví dụ :

```
#iptables -A OUTPUT -p icmp --icmp-type echo-request -j ACCEPT  
#iptables -A INPUT -p icmp --icmp-type echo-reply -j ACCEPT
```

Trong ví dụ này Iptables cho phép các máy tính trong mạng nội bộ ping ra ngoài .

2.2.3.3 Chặn dựa trên trạng thái kết nối.

Bảng 2.4. Tùy chọn chặn dựa trên trạng thái kết nối trong IPtables.

Sử dụng với tùy chọn -m multiport	Giải thích
--sport <port, port>	Sử dụng để chỉ ra nhiều port nguồn
--dport <port, port>	Sử dụng để chỉ ra nhiều port đích
--state <state>	Sử dụng với các tùy chọn trạng thái như ESTABLISHED ,NEW , RELATED

Ví dụ:

```
#iptables -A FORWARD -s 0/0 -i eth0 -d 192.168.1.58 -o eth1 -p TCP  
--sport 1024:65535 -m multiport --dport 80,443 -j ACCEPT
```

Trong ví dụ trên Iptables cho phép chuyển các gói tin từ eth0 đến eth1 với điều kiện các gói tin có địa chỉ nguồn bất kỳ và địa chỉ đích là 192.168.1.58 , giao thức TCP có port nguồn từ 1024 đến 65535 và port đích là 80 (http) và 443 (SSL).

```
#iptables -A FORWARD -d 0/0 -o eth0 -s 192.168.1.58 -i eth1 -p TCP  
-m state --state ESTABLISHED -j ACCEPT
```

Trong ví dụ trên Iptables cho phép chuyển các gói tin từ eth0 đến eth1 với điều kiện các gói tin có địa chỉ nguồn bất kỳ và địa chỉ đích là 192.168.1.58 , giao thức TCP với trạng thái kết nối mới.

2.2.4. Cài đặt Iptables.

2.2.4.1. Các câu lệnh trợ giúp.

`#iptables -h`

`#iptables -m match -h`

`#iptables -j TARGET -h`

`#man iptables`

2.2.4.2. Các tùy chọn.

Bảng 2.5. Các tùy chọn trong IPTables.

Tùy chọn	Giải thích
-A (--append)	Ghi thêm một rule vào chain
-D (--delete)	Xóa rule
-E (--rename-chain)	Đổi tên chain
-F (--flush)	Xóa tất cả rule trong một chain
-I (--insert)	Chèn thêm rule vào chain tại vị trí được xác định
-L (--list)	Xem các rule trong chain
-N (--new-chain)	Tạo một chain mới
-P (--policy)	Tạo rule mặc định cho chain
-R (--replace)	Thay thế một rule bằng một rule khác tại vị trí xác định

-V (--version)	Xem phiên bản của Iptables
-X (--delete-chain)	Xóa chain
-Z (--zero)	Xóa bộ đếm trong chain
-t	Chỉ định bảng cho iptables bao gồm: filter, nat, mangle tables
-j	Nhảy đến một target
-p	Mô tả các giao thức bao gồm: icmp, tcp, udp và all
-s	Chỉ định địa chỉ nguồn
-d	Chỉ định địa chỉ đích
-i	Chỉ định địa chỉ interface cho các gói tin đi vào
-o	Chỉ định địa chỉ interface cho các gói tin đi ra
-m multiport	Chỉ định nhiều dãy cổng
-m state --state	Kiểm tra trạng thái: ESTABLISHED: đã thiết lập connection NEW: bắt đầu thiết lập connection

	RELATED: thiết lập connection thứ 2
--	-------------------------------------

2.2.4.3. Các câu lệnh phục hồi.

- iptables-restore : lệnh phục hồi iptables có hai tùy chọn :

Bảng 2.6. Câu lệnh hồi phục và các tùy chọn.

Tùy chọn	Giải thích
-c (--counters)	Phục hồi bộ đếm gói và byte cho các rule
-n (--noflush)	Tắt chức năng xóa (-flush) trong tables trước khi phục hồi

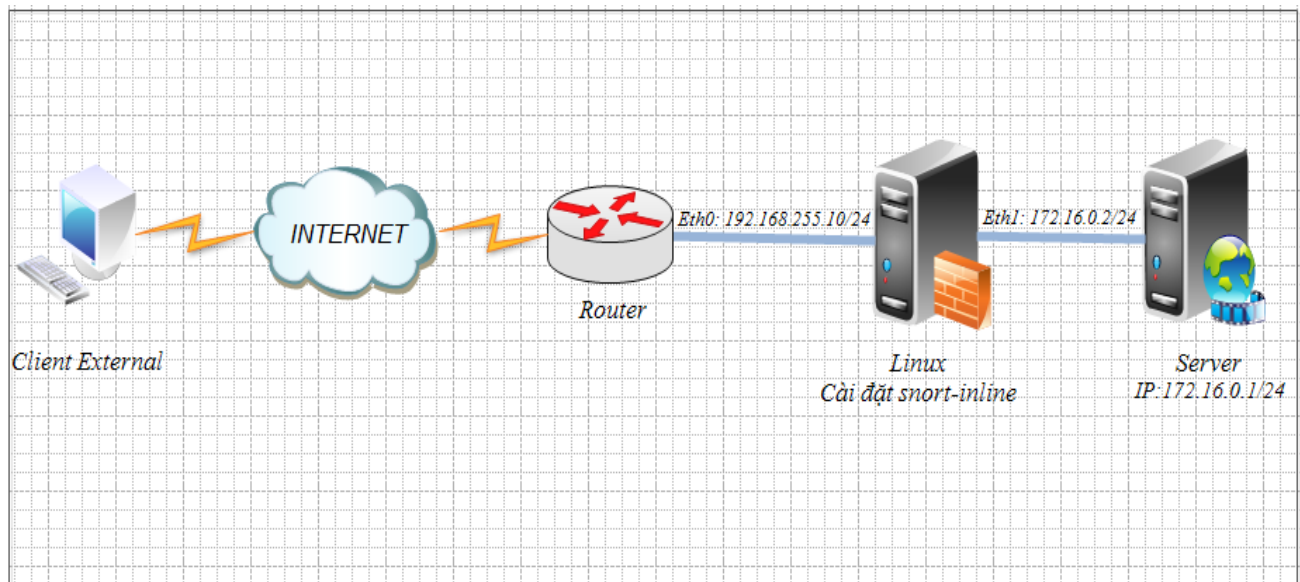
-iptables-save : lệnh ghi lại Iptables có hai tùy chọn:

Bảng 2.7. Câu lệnh hồi phục và các tùy chọn.

Tùy chọn	Giải thích
-c (--counters)	Hiện bộ đếm gói và byte cho các rule
-t (--table)	Chỉ hiện bảng được chỉ định

CHƯƠNG 3: TRIỂN KHAI SNORT VÀ IPTABLES

3.1. Mô hình hệ thống.



Hình 3.1. Mô hình hệ thống.

3.2. Triển khai mô hình hệ thống.

3.2.1 Cài đặt và cấu hình snort.

3.2.1.1 Cài đặt các gói phụ thuộc.

Trước khi bước vào tiến hành cài đặt snort thì phải các gói phụ thuộc sau:

Để cài đặt các gói này chúng ta sử dụng lệnh: `yum install <tên gói>`

Bảng 1.1. Danh sách các gói phụ thuộc.

Mysql	httpd	Php-gd	Mod_ssl
Mysql-devel	Yum-utils	gd	Glib2-devel
Mysql-bench	gcc	Php-mysql	Gcc-c++

Mysql-server	Pcre-devel	Distcache-devel	Libpcap-devel
Php	Php-pear	Iptables	Iptables-devel

Ngoài ra một số gói cần phải biên dịch từ nguồn như: flex, bison, libpcap, libnet, libdnet, pcre.

Download tại:

Flex: <http://www.4shared.com/archive/WLHiHTSu/flex-2535tar.html>

Bison: <http://ftp.gnu.org/gnu/bison/bison-2.4.1.tar.gz>

Libpcap-1.0.0: <http://www.filewatcher.com/m/libpcap-1.0.0.tar.gz.524273-0.html>

Libnet: <http://sourceforge.net/projects/libnet/files/>

Libdnet: <http://code.google.com/p/libdnet/downloads/detail?name=libdnet-1.12.tgz&can=2&q=>

Pcre: <ftp://ftp.csx.cam.ac.uk/pub/software/programming/pcre/pcre-7.9.tar.gz>

Sau khi download về tiến hành biên dịch cho các gói: Dùng lệnh `tar xzvf <tên gói>` để thực hiện giải nén, `cd <thư mục gói được giải nén>` di chuyển vào thư mục gói vừa được giải nén, `./configure && make && make install` câu lệnh này dùng kiểm tra cấu hình và biên dịch gói, dấu `&&` có ý nghĩa nếu câu lệnh trước nó thành công thì mới thực hiện câu lệnh đứng sau.

Để kiểm tra các gói phụ thuộc đã được cài đặt đủ dùng câu lệnh: `rpm -qa|grep <tên gói>`.

3.2.1.2 Cài đặt snort.

Download gói `snort-2.8.6.1.tar.gz` từ địa chỉ <http://brakertech.com/snort-2-8-6-1-tar-gz/>

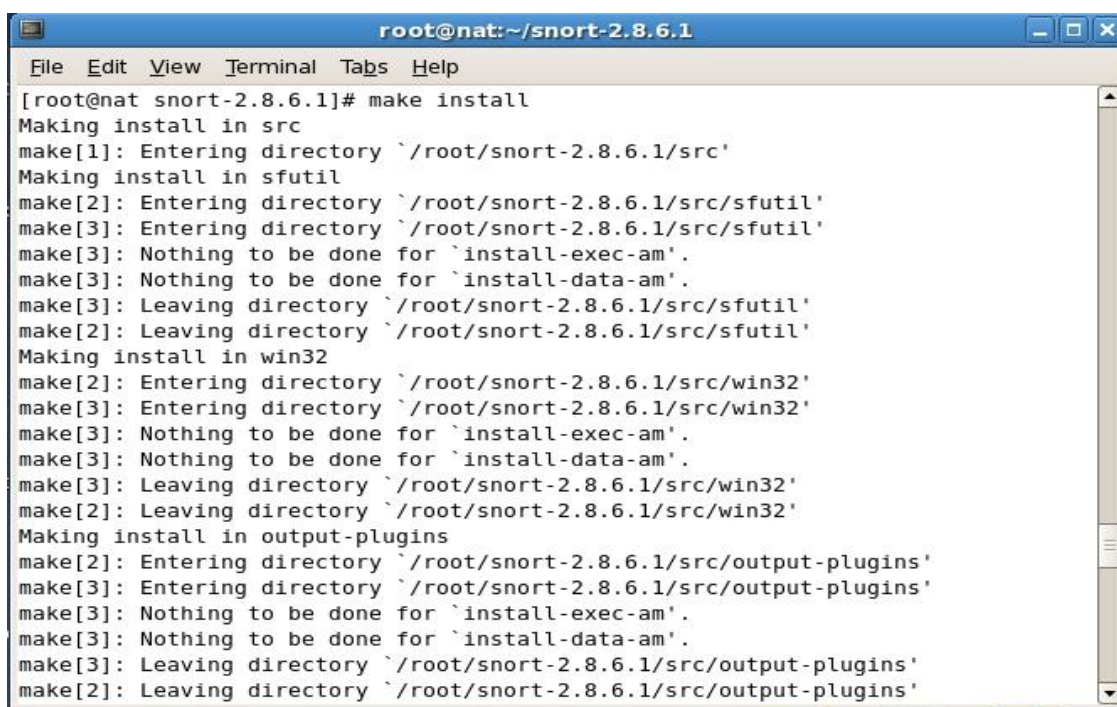
giải nén và tiến hành cài đặt lần lượt bằng câu lệnh: `tar -xzf snort-2.8.6.1.tar.gz`

(giải nén gói snort), di chuyển vào thư mục vừa giải nén thực hiện lệnh.

```
# ./configure --with-mysql --enable-inline
```

Nếu không có lỗi xảy ra tiếp tục chạy lệnh:

```
# make && make install
```



Hình 1.1. Cài đặt snort.

3.2.1.3 Cấu hình Snort.

Tạo các thư mục hoạt động cho snort sử dụng lệnh sau:

```
# mkdir /etc/snort (lưu trữ file hệ thống và cấu hình của snort).
```

```
# mkdir /etc/snort/rules (lưu trữ các luật áp dụng cho snort).
```

```
# mkdir /var/log/snort (lưu trữ sự kiện xảy ra của hệ thống).
```

Chép các file cấu hình:

```
# cd snort-2.8.6.1
```

```
# cd etc/
```

```
# cp */etc/snort
```

Tạo và set quyền cho user, nhóm người dùng:

```
# groupadd snort (tạo nhóm người dùng).
```

```
# useradd -g snort duyvhit -s /sbin/nologin (tạo user và thêm vào nhóm).
```

```
# chown duyvhit:snort /var/log/snort/ (xét quyền sở hữu và cho phép snort ghi log vào thư mục chứa log).
```

Cài đặt rule cho snort: download tập rule từ địa chỉ sau:

<http://www.4shared.com/archive/p-bSNuib/snortrules-snapshot-28tar.html>

giải nén và copy vào thư mục chứa rule.

```
#tar -xzf snortrules-snapshot-2.8.tar.gz
```

```
#cd snortrules-snapshot-2.8
```

```
#cd rules
```

```
#cp */etc/snort/rules
```

Chỉnh sửa file snort.conf:

```
nano /etc/snort/snort.conf
```

`var HOME_NET 192.168.0.0/24` (cấu hình cho phép sử dụng HOME_NET thay cho địa chỉ mạng bên trong, sửa tại dòng 25).

`var RULE_PATH /etc/snort/rules` (cấu hình đường dẫn chứa rules để áp dụng cho snort, sửa tại dòng 60).

`Output database: log, mysql, user=snort password=010203 dbname=snort host=localhost` (cấu hình thông tin lưu trữ cơ sở dữ liệu cho snort, lưu ý đối với phiên bản mới có thể không có sẵn mà chúng ta phải thiết lập mới).

Thiết lập snort cùng khởi động với hệ thống:

Tạo một liên kết mềm (symbolic link) của file snort binary đến /usr/sbin/snort

```
ln -s /usr/local/bin/snort /usr/sbin/snort
```

Snort cung cấp các scrip để khởi động trong thư mục rpm/ ; (thư mục giải nén snort)

```
cp /snort/snort-2.8.4.1/rpm/snortd /etc/init.d/
```

```
cp /snort/snort-2.8.4.1/rpm/snort.sysconfig /etc/sysconfig/snort
```

Đặt quyền lại cho file snortd :

```
chmod 755 /etc/init.d/snortd
```

```
chkconfig snortd on
```

```
service snortd start
```

Để khởi động snort ở chế độ debug nếu bạn muốn kiểm tra lỗi:

```
/snort/snort-2.8.4.1/src/snort -u snort -g snort -d -c /etc/snort/snort.conf
```

Tạo cơ sở dữ liệu cho snort với MySQL:

```
# service mysqld start (khởi chạy dịch vụ MySQL).
```

```
# mysqladmin -u root password <mật khẩu root> (tạo mật khẩu cho root).
```

```
# mysql -p
```

```
> use mysql;
```

```
> create user 'snort'@'localhost' IDENTIFIED BY '010203' (tạo user viethanit trên cơ sở dữ liệu).
```

```
> create database snort; (tạo cơ sở dữ liệu snort).
```

```
>mysql> GRANT CREATE, INSERT, SELEC, DELETE, UPDATE ON
```

```
Snort.* to snort@localhost; (gán quyền cho user).
```

```
> flush privileges; (reload lại MySQL privileges).
```

```
> exit;
```

Tạo bảng cho cơ sở dữ liệu snort:

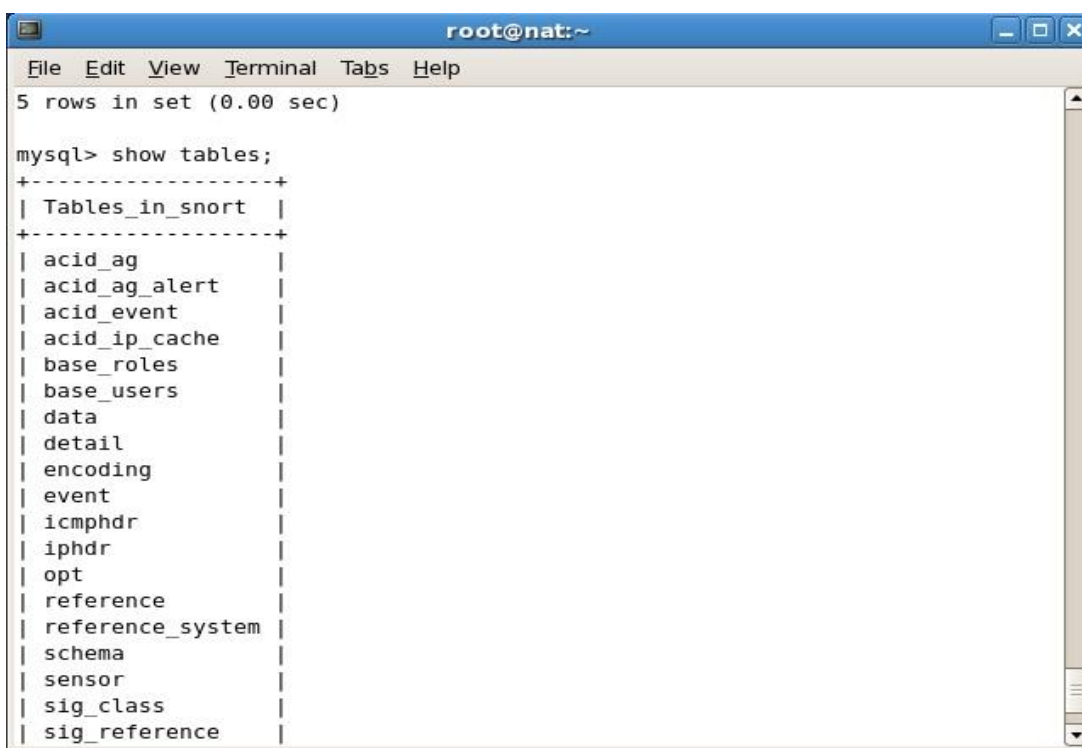
```
# mysql -u root -p snort < /<đường dẫn đến thư mục file snort-2.8.6.1>/schemas/create_mysql
```

```
# mysql -p
```

```
# show databases; (hiển thị cơ sở dữ liệu đã tạo).
```

```
# use snort;
```

```
# show tables; (kiểm tra các bản đã được tạo trong cơ sở dữ liệu).
```



Hình 1.2. Danh sách các bảng đã được tạo ra.

3.2.1.4 Cài đặt và cấu hình base và adodb.

Trước tiên chúng ta cài đặt các gói phụ thuộc cần thiết để hiển thị được cảnh báo dưới dạng biểu đồ.

Cài đặt bằng lệnh sau:


```
#pear install Image_Graph-alpha Image_Canvas-alpha Image_Color  
Numbers_Roman
```

Cài đặt base và adodb giúp người quản trị có thể giám sát hệ thống được trực quan hơn qua giao diện web giúp người quản trị có những biện pháp áp dụng kịp thời cho hệ thống.

- Cài đặt base:

Download bản cài đặt: <http://sourceforge.net/projects/secureideas/files/>.

```
# tar -xzf base-1.4.5.tar.gz (giải nén gói base vừa download).
```

```
# mv /base-1.4.5/ /var/www/html/base (di chuyển vào thư mục var/www/html  
và đổi tên thành base).
```

-Cài đặt adodb:

Download bản cài đặt <http://adodb.sourceforge.net/#download>.

```
# tar -xzf adodb506a.tgz (giải nén gói adodb).
```

```
# mv adodb506a /var/www/html/adodb (di chuyển vào thư mục  
/var/www/html và đổi tên thành adodb).
```

-Cấu hình base:

```
#chmod 777 -R /var/www/html/base (phân quyền cho thư mục base).
```

```
#mv/var/www/html/base/base_conf.php.dist/var/www/html/base/base_conf.php  
(đổi tên file cấu hình base_conf.php.dist thành base_conf.php).
```

```
# vi /var/www/html/base/base_conf.php (chỉnh sửa file cấu hình  
base_conf.php).
```

Chỉnh lại thông số ở các dòng sau :

```
$DBlib_path = '/var/www/html/adodb5';  
  
$DBtype = 'mysql';
```

```
$alert_dbname = 'snort';  
$alert_host = 'localhost';  
$alert_port = "";  
$alert_user = 'snort';  
$alert_password = '010203';  
$archive_exists = 1; # Set this to 1 if you have an archive DB  
$archive_dbname = 'snort';  
$archive_host = 'localhost';  
$archive_port = "";  
$archive_user = 'snort';  
$archive_password = '010203';  
/* Whois query */  
$external_whois_link = 'index.php';  
/* DNS query */  
$external_dns_link = 'index.php';  
/* SamSpade "all" query */  
$external_all_link = 'index.php';
```

Thực hiện import các bảng của base vào trong cơ sở dữ liệu của snort:

```
# mysql -u root -p snort < /var/www/html/base/sql/create_base_tbls_mysql.sql
```

3.2.1.5 Cấu hình chế độ mod inline.

Đối với các phiên bản cao của snort được tích hợp thêm chức năng mode inline có khả năng ngăn chặn xâm nhập kết hợp với iptables.

- Load ip_queue:

modprobe ip_queue (lệnh modprobe giúp chèn một module vào kernel đang chạy).

lsmod |grep ip_queue (kiểm tra lại ip_queue đã được nạp lên kernel).

-Cấu hình iptables:

iptables -A INPUT -j QUEUE (câu lệnh với thông số -A để nối thêm một quy luật vào chuỗi, -j để nhảy đến một mục tiêu khác (target) khi gói dữ liệu phù hợp. Ở câu lệnh trên các gói tin đi vào bên trong sẽ được đẩy vào hàng đợi).

3.2.1.6 Khởi chạy snort-inline.

snort -Q -v -c /etc/snort/snort.conf -l /var/log/snort

-Q: Các gói tin sẽ được đưa vào hàng đợi chờ snort xử lý.

-v: In toàn bộ packet trên console (lưu ý khi dùng, có thể làm cho Snort chậm đi khi drop packet).

-c: Chỉ định file cấu hình nào muốn sử dụng, cần thiết khi Snort chạy ở mode NIDS.

-l: Chỉ định thư mục để log các alter. Mặc định thư mục log là /var/log/Snort.

Ngoài ra snort còn một số thông số khác như:

-V: hiển thị phiên bản của snort.	-d: Hiển thị dữ liệu ở tầng application khi dùng chế độ hiển thị đầy đủ hoặc trong packet logging mode.	-e: Hiển thị hoặc log các lớp liên kết packet headers. thường dùng khi capture packet khi chạy Snort ở chế độ Sniffing.	-i: chỉ định interface nào snort sẽ lắng nghe.
-----------------------------------	---	---	--

-P: Thiết lập chiều dài tối đa cho các packet capture. Thiết lập để có thể bắt hết các packet, nếu thiết lập chiều dài quá ngắn có thể không coi hết được nội dung của packet khi cần thiết.	-q: Không hiển thị banner hay những thông tin khi khởi động.	-s: Gửi alert message đến syslog server. Có thể gửi ở local hay remote server.	-?: Danh sách các option và thoát.
--	--	--	------------------------------------

Bảng 2.1. Các tùy chọn trong snort-inline.

```

root@nat:/var/www/html/base
File Edit View Terminal Tabs Help
| Memory      : 18.60Mbytes
| Patterns    : 4.06M
| Match Lists : 5.49M
| Transitions : 8.94M
+-----+
[ Number of null byte prefixed patterns trimmed: 17281 ]

--- Initialization Complete ---

--> Snort! <*-
Version 2.8.6.1 (Build 39) inline
By Martin Roesch & The Snort Team: http://www.snort.org/snort/snort-team

Copyright (C) 1998-2010 Sourcefire, Inc., et al.
Using PCRE version: 6.6 06-Feb-2006

Rules Engine: SF_SNORT_DETECTION_ENGINE Version 1.12 <Build 18>
Preprocessor Object: SF_DCERPC2 Version 1.0 <Build 3>
Preprocessor Object: SF_SDF Version 1.1 <Build 1>
Preprocessor Object: SF_DCERPC Version 1.1 <Build 5>
Preprocessor Object: SF_FTPTELNET Version 1.2 <Build 13>
Preprocessor Object: SF_DNS Version 1.1 <Build 4>
Preprocessor Object: SF_SSH Version 1.1 <Build 3>
Preprocessor Object: SF_SSLPP Version 1.1 <Build 4>
Preprocessor Object: SF_SMTP Version 1.1 <Build 9>
  
```

Hình 1.3. Khởi động snort thành công.

3.2.2 Kiểm tra.

3.2.2.1 Tạo rule phát hiện .

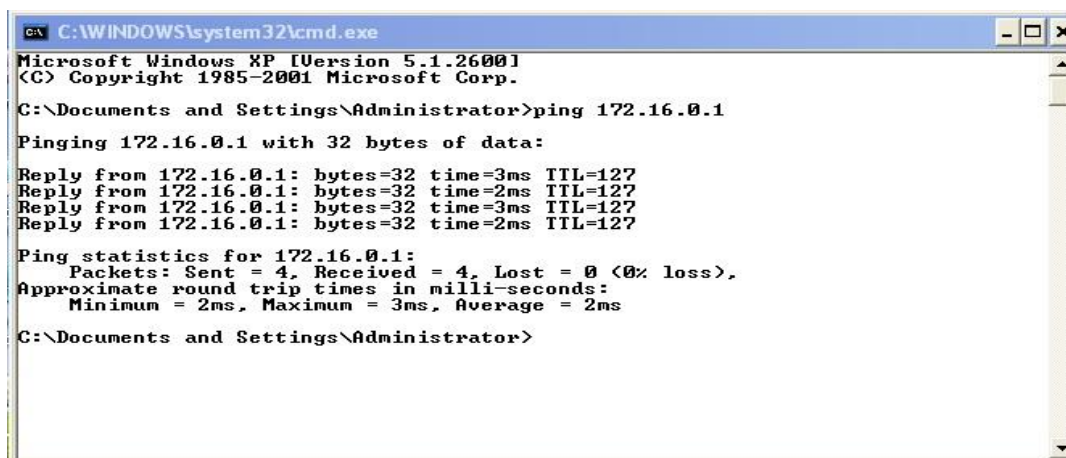
Thực hiện kiểu tấn công *Ping of Deal* từ máy client thuộc external vào máy server thuộc vùng internal

Tạo rule *ping.rules* : # ví /etc/snort/rule/ping.rules với nội dung

alert icmp any any → 172.16.0.1 any (msg: “server đang bị ping”; sid: 1001;)

Với rule trên snort sẽ đưa ra cảnh báo “server đang bị ping” khi có một máy bất kì thực hiện lệnh ping đến cổng bất kì của server có địa chỉ 172.16.0.1.

Khởi chạy snort và tiến hành ping từ client:



```
C:\WINDOWS\system32\cmd.exe
Microsoft Windows XP [Version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\Documents and Settings\Administrator>ping 172.16.0.1

Pinging 172.16.0.1 with 32 bytes of data:

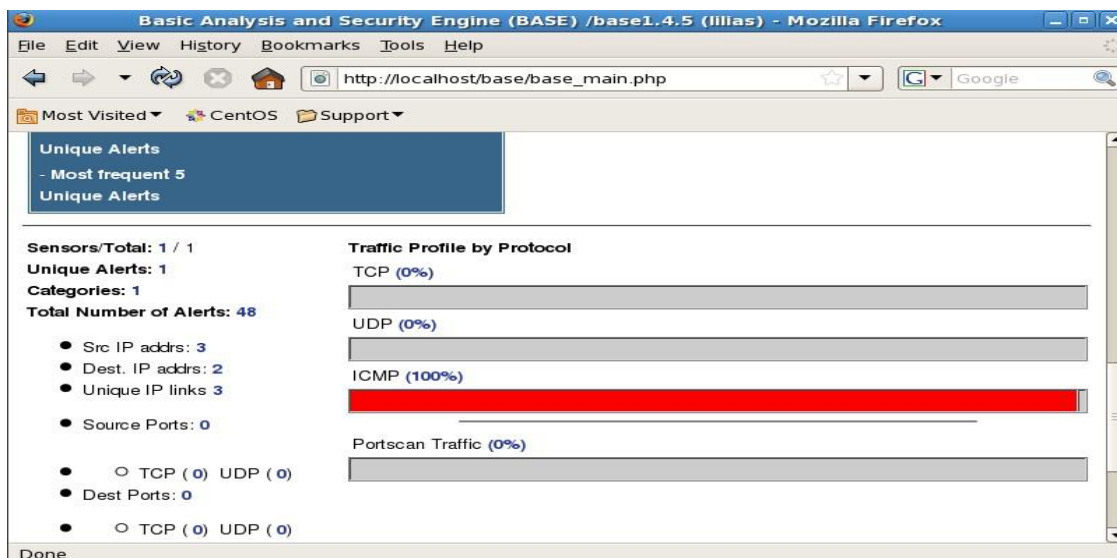
Reply from 172.16.0.1: bytes=32 time=3ms TTL=127
Reply from 172.16.0.1: bytes=32 time=2ms TTL=127
Reply from 172.16.0.1: bytes=32 time=3ms TTL=127
Reply from 172.16.0.1: bytes=32 time=2ms TTL=127

Ping statistics for 172.16.0.1:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 2ms, Maximum = 3ms, Average = 2ms

C:\Documents and Settings\Administrator>
```

Hình 1.4. Thực hiện ping từ client.

Snort phát hiện cảnh báo với giao thức ICMP với mức độ 100%.



Hình 1.5. Hiển thị mức độ cảnh báo.

Các cảnh báo được hiển thị với thông tin như dấu hiệu, thời gian, địa chỉ nguồn, đích, giao thức sử dụng.

The screenshot shows the 'Query Results' page in BASE. A table of alerts is displayed, with alert #1 highlighted in red. The table columns are ID, Signature, Timestamp, Source Address, Dest. Address, and Layer 4 Proto.

ID	Signature	Timestamp	Source Address	Dest. Address	Layer 4 Proto
#0-(11-76)	[arachNIDS] [snort] sever dang bi ping	2011-06-11 01:03:05	172.16.0.1	192.168.2.2	ICMP
#1-(11-75)	[arachNIDS] [snort] sever dang bi ping	2011-06-11 01:03:05	192.168.2.2	172.16.0.1	ICMP
#2-(11-74)	[arachNIDS] [snort] sever dang bi ping	2011-06-11 01:03:04	172.16.0.1	192.168.2.2	ICMP
#3-(11-73)	[arachNIDS] [snort] sever dang bi ping	2011-06-11 01:03:04	192.168.2.2	172.16.0.1	ICMP
#4-(11-72)	[arachNIDS] [snort] sever dang bi ping	2011-06-11 01:03:03	172.16.0.1	192.168.2.2	ICMP
#5-(11-71)	[arachNIDS] [snort] sever dang bi ping	2011-06-11 01:03:03	192.168.2.2	172.16.0.1	ICMP
#6-(11-70)	[arachNIDS] [snort] sever dang	2011-06-11	172.16.0.1	192.168.2.2	ICMP

Hình 1.6. Hiển thị các thông tin cảnh báo.

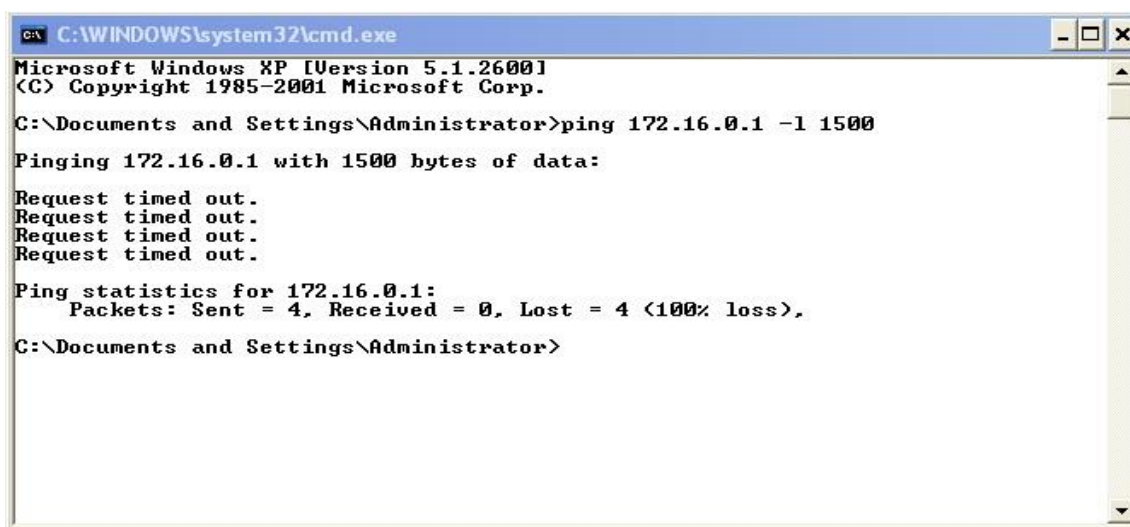
3.2.2.2 Tạo rule ngăn chặn.

Thực hiện tạo rule ngăn chặn kiểu tấn công *Ping of Deal* từ máy client thuộc external vào máy server thuộc vùng internal bằng cách quy định kích thước các gói tin ICMP .

Tạo rule *dping.rules* : # vi */etc/snort/rules/dping.rules* với nội dung

```
drop icmp any any <> 172.16.0.1 any (msg: 'chan ping >1000 byte'; dsize:>1000; sid: 10002;)
```

Rule trên sẽ thực hiện chặn lệnh ping từ máy bất kì có kích thước lớn hơn 1000 bytes.



Hình 1.7. Thực hiện lệnh ping có kích thước 1500 bytes.

Snort đã dựa vào rule được viết và áp dụng ngăn chặn lại đồng thời thông báo đến người quản trị.

Displaying alerts 1-48 of 433 total

ID	< Signature >	< Timestamp >	< Source Address >	< Dest. Address >	< Layer 4 Proto >
☐ #0-(11-433)	[arachNIDS] [snort] sever dang bi ping	2011-06-14 12:02:30	172.16.0.3	172.16.0.1	ICMP
☐ #1-(11-432)	[arachNIDS] [snort] sever dang bi ping	2011-06-14 12:02:28	172.16.0.3	172.16.0.1	ICMP
☐ #2-(11-431)	[snort] chan ping > 1000 byte	2011-06-14 12:02:24	192.168.2.2	172.16.0.1	ICMP
☐ #3-(11-430)	[arachNIDS] [snort] sever dang bi ping	2011-06-14 12:02:23	172.16.0.3	172.16.0.1	ICMP
☐ #4-(11-429)	[arachNIDS] [snort] sever dang bi ping	2011-06-14 12:02:21	172.16.0.3	172.16.0.1	ICMP
☐ #5-(11-428)	[snort] chan ping > 1000 byte	2011-06-14 12:02:19	192.168.2.2	172.16.0.1	ICMP

Done

Hình 1.8. Thông tin ngăn chặn của Snort.

KẾT LUẬN

Vấn đề bảo mật an toàn thông tin, nó không chỉ là vấn đề của một người, một doanh nghiệp, một tập đoàn mà nhìn rộng ra thì đó là vấn đề của cả một quốc gia, của cả xã hội.

Việc bảo vệ, phát hiện, ngăn chặn các hành động xâm nhập truy nhập đã, đang và sẽ luôn là vấn đề rất cần thiết không chỉ đối với những chuyên gia an ninh mạng mà còn với tất cả những người tham gia vào mạng máy tính và Internet.

Tuy nhiên, do thời gian có hạn và kiến thức thực tiễn còn hạn chế nên em chưa thể tìm hiểu và trình bày kỹ lưỡng, xác đáng về các vấn đề liên quan. Đây mới chỉ là một phần rất nhỏ mà đề tài có thể cung cấp trong bối cảnh an ninh thông tin hiện nay.

Kết quả đạt được:

- Tìm hiểu về hệ điều hành Linux.
- Nắm bắt được cơ chế hoạt động của hệ thống phát hiện xâm nhập IDS/IPS.
- Cài đặt và cấu hình một hệ thống phát hiện và ngăn ngừa xâm nhập mã nguồn mở Snort.
- Vận dụng những hiểu biết viết được một số luật đơn giản cho Snort.
- Sử dụng được các sản phẩm phân tích cảnh báo trong Snort như: MySQL, BASE, Snort_inline

Hạn chế của đề tài:

- Demo còn khá khiêm tốn, chưa nêu rõ hết được công dụng của hệ thống IDS/IPS.
- Tập rules chưa viết hoàn chỉnh.
- Chưa tìm hiểu và viết rule cho những dạng tấn công phức tạp.
- Chưa nắm hết được chức năng web base.

Hướng phát triển:

- Tiếp tục nghiên cứu và phát triển theo hướng tối ưu hóa hệ thống hiện tại để tránh các lỗi bảo mật mắc phải.

- Viết ra các rule riêng để phát hiện ra các hình thức tấn công mới.

Cuối cùng, một lần nữa em xin chân thành cảm ơn thầy giáo Nguyễn Vũ đã hướng dẫn, giúp đỡ em trong suốt quá trình làm đề tài tốt nghiệp này.

TÀI LIỆU THAM KHẢO

+ Tiếng việt:

[1] Slide môn mạng máy tính, TCP/IP, quản trị mạng linux của khoa khoa học máy tính trường cao đẳng công nghệ thông tin hữu nghị việt – hàn.

[2] Cài đặt và Cấu hình iptables của Nguyễn Hồng Thái, Đại học Công nghệ Thành phố Hồ Chí Minh.

+ Tiếng anh:

[3] Iptables Tutorial 1.2.2 Oskar Andreasson - Copyright © 2001-2005 Oskar Andreasson.

[4] O'Reilly (2004) - Managing Security With Snort And Ids Tools - 1st

[5] Sourcefire (2009) - SNORT Users Manual.

[6] Rafeeq Ur Rehman (2005) - Intrusion [Detection](#) Systems with Snort: Advanced IDS Techniques with Snort, Apache, MySQL, PHP, and ACID.

[7] Kerry J. Cox, Christopher Gerg (8-2004), “Managing Security with Snort and IDS Tools”

[8] Các website:

1. <http://www.google.com.vn>
2. <http://www.linuxhomenetworking.com/>
3. <http://www.hvaonline.net>
4. <http://wiki.centos.org/HowTos/Network/IPTables>
5. <http://www.snort.org>

This image shows a full page of primary-ruled paper. It features multiple sets of horizontal dotted lines, each set consisting of three lines. These lines are evenly spaced across the entire page, providing a guide for handwriting practice. The background is white, and there are no margins or other markings present.

